



資安職能訓練- 資通安全概論 (第1天)

數位發展部資通安全署 編製



課程簡介

- 本課程時間為18小時(3天)
- 課程涵蓋資通安全策略面、管理面及技術面之資安議題及防護措施。內容包含：
 - 資通安全基本觀念
 - 資通安全相關法規
 - 資通安全風險管理
 - 資通安全管理面暨認知與訓練應辦事項
 - 資通系統防護控制措施
 - 資通安全技術面應辦事項
 - 資訊委外安全管理
 - 資通安全事件通報應變及演練



課程學習目標

- 本課程的目標為幫助學員建立資通安全領域的基礎背景，使其具備職務上所需要的資安知識與技能，同時為其他的資安相關教育訓練課程建立先備知識。
- 課程內容以實用性為主軸，配合資通安全在策略面、管理面及技術面，全面性涵蓋資通安全之相關領域，並配合淺顯易懂的介紹或實例說明，避免太理論與深入複雜的學理研究。



第1天課程大綱

時段	課程單元	
上午	第1單元	資通安全基本觀念
	第2單元	資通安全相關法規
下午	第3單元	資通安全風險管理
	第4單元	資通安全管理面暨認知與訓練 應辦事項



第2天課程大綱

時段	課程單元	
上午	第5單元	資通系統防護控制措施
下午	第6單元	資通安全技術面應辦事項 - 資通安全防護及偵測



第3天課程大綱

時段	課程單元	
上午	第7單元	資通安全技術面應辦事項- 安全性檢測及資通安全健診
下午	第8單元	資訊委外安全管理
	第9單元	資通安全事件通報應變及演練



第1單元

資通安全基本觀念



第1單元學習目標

- ✓ 1-1 了解資通系統之組成
- ✓ 1-2 建立資通安全之危機意識
- ✓ 1-3 了解資通安全之防護目標



1-1 資通系統之組成(1/3)

- **資通系統**：指用以蒐集、控制、傳輸、儲存、流通、刪除資訊或對資訊為其他處理、使用或分享之系統
(資通安全管理法§3 I)
 - 如考選部全球資訊網、eCPA人事服務網、公文系統、差勤系統等



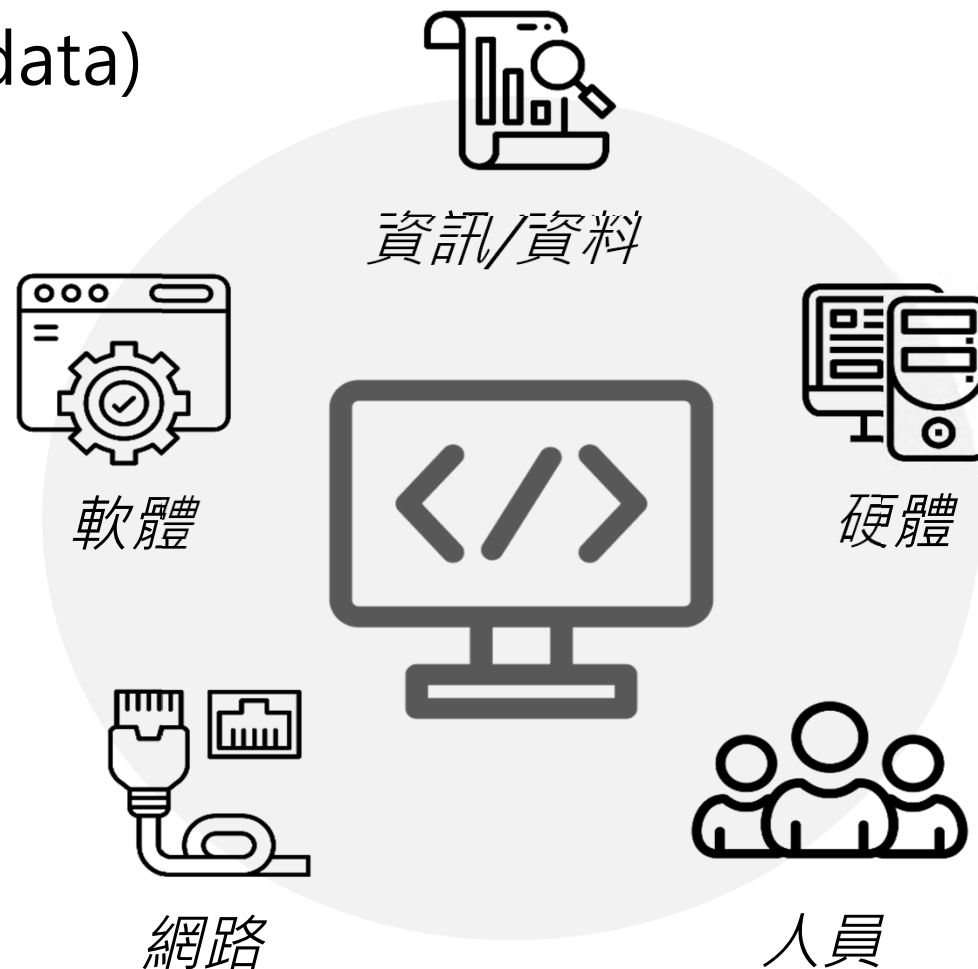
- **資通服務**：指與資訊之蒐集、控制、傳輸、儲存、流通、刪除、其他處理、使用或分享相關之服務
(資通安全管理法§3 II)
 - 如個人電腦維護、伺服器維護等



1-1 資通系統之組成(2/3)

■ 我們要保護的是什麼？

- 資訊/資料(Information/data)
- 軟體 (Software)
- 硬體 (Hardware)
- 網路 (Network)
- 人員 (People)

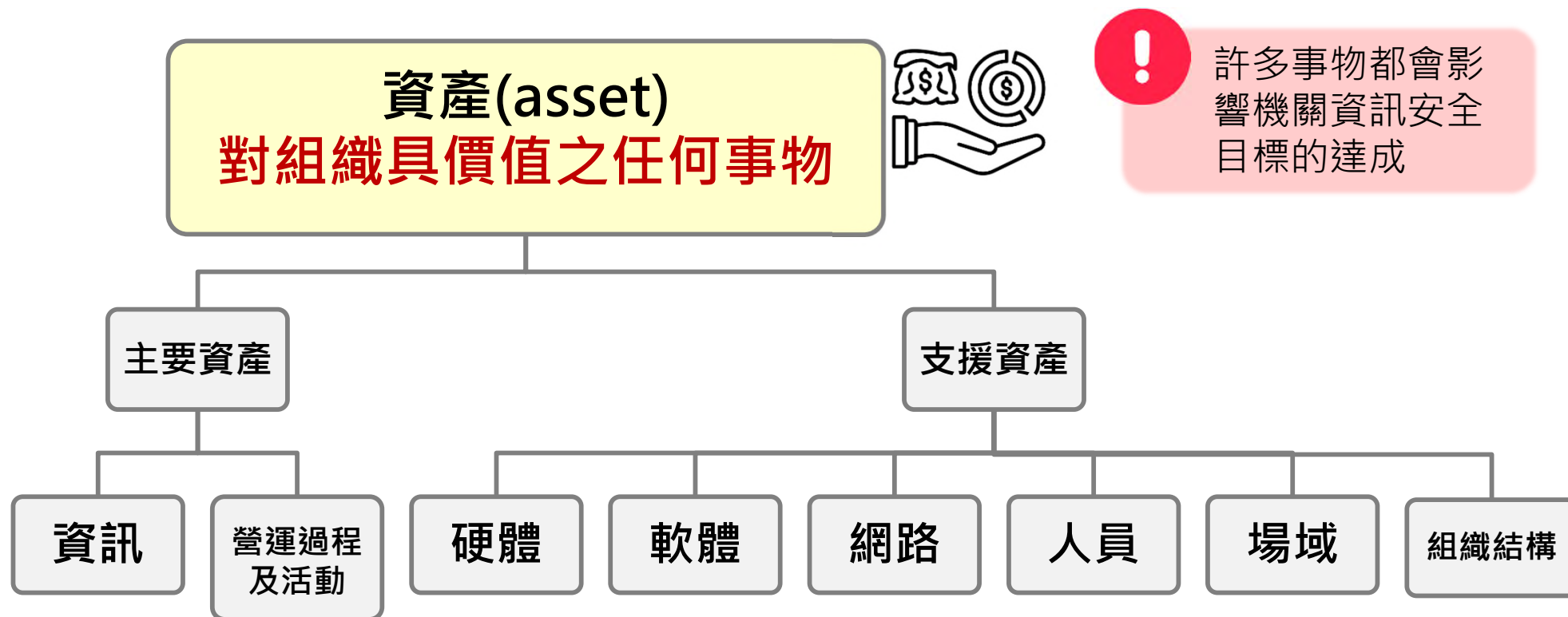




1-1 資通系統之組成(3/3)

■ CNS 27002 : 2023 資訊安全、網宇安全及隱私保護-資訊安全控制措施

(Information security, cybersecurity and privacy protection – Information security controls) :





1-2 建立資通安全之危機意識

■ 從建立資通安全的危機意識開始

- 資安面臨的危害，可能產生超出一般人的想像
 - 當資通系統遭到資安攻擊而停擺時，會造成重大影響
- 資安面臨的攻擊無孔不入，影響層面大
 - 物聯網帶來了商機，是否也引來了危機
 - 行動與無線通訊帶來了方便，是否也會造成更大不便
- 資安是每一個人應有的責任與警覺
 - 資安與國家安全息息相關
 - 資安素養是現代公民需要培養的生活與工作知能



1-3 資通安全之目標(1/7)

■ 什麼是資通安全

➤ 資通安全：

指防止資通系統或資訊遭受未經授權之存取、使用、控制、洩漏、破壞、竄改、銷毀，或其他情形影響其機密性、完整性或可用性（資通安全管理法§3 III）

- Protect assets from unauthorized actions

➤ 資通安全事件：

指系統、服務或網路狀態經鑑別而顯示可能有違反資通安全或保護措施失效之狀態發生，影響資通系統機能運作（資通安全管理法§3 IV）

- 如發生個資電子檔外洩、系統資料遭勒索病毒加密破壞、系統當機無法正常提供服務等情形

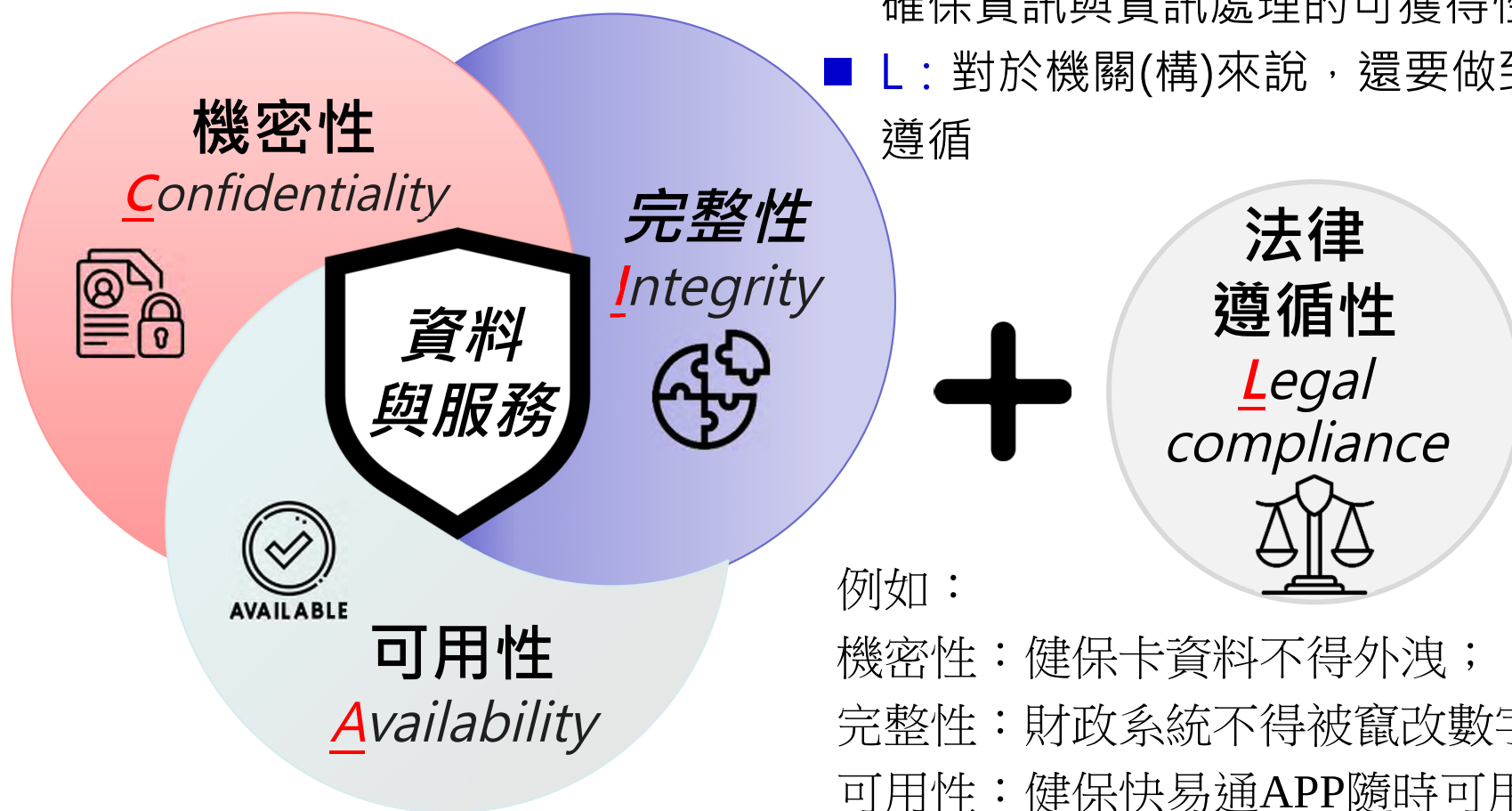




1-3 資通安全之目標(2/7)

- **C**：防止非授權人員存取資訊，確保資訊秘密性
- **I**：防止非授權人員竄改資訊，確保資訊正確性

- **A**：防止系統故障或人為惡意阻斷服務，確保資訊與資訊處理的可獲得性
- **L**：對於機關(構)來說，還要做到法規的遵循



例如：

- 機密性：健保卡資料不得外洩；
- 完整性：財政系統不得被竄改數字；
- 可用性：健保快易通APP隨時可用」



1-3 資通安全之目標(3/7)

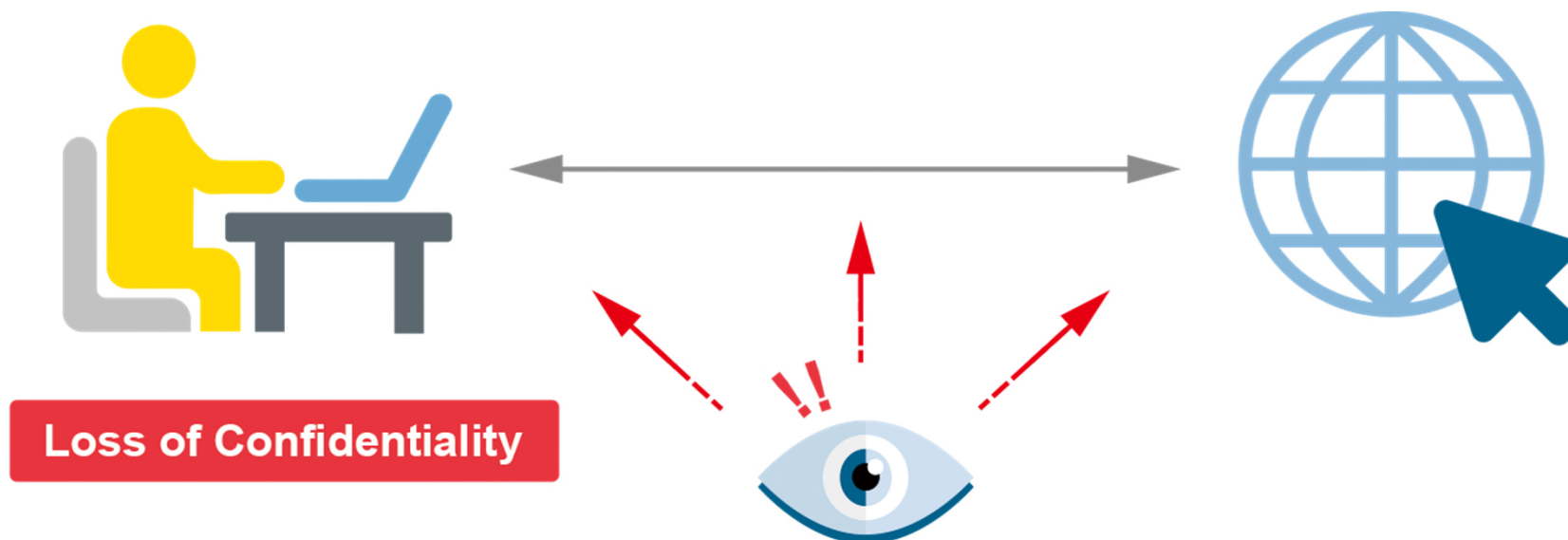
■ 機密性(Confidentiality)

- **意涵**：敏感資訊只能經由授權之人員或系統存取

Sensitive information is accessible only to authorized individuals or systems

- **目標**：防止非授權人員存取資訊，確保資訊秘密性

- **解決方案**：加密、存取控制、資料遮罩等





1-3 資通安全之目標(4/7)

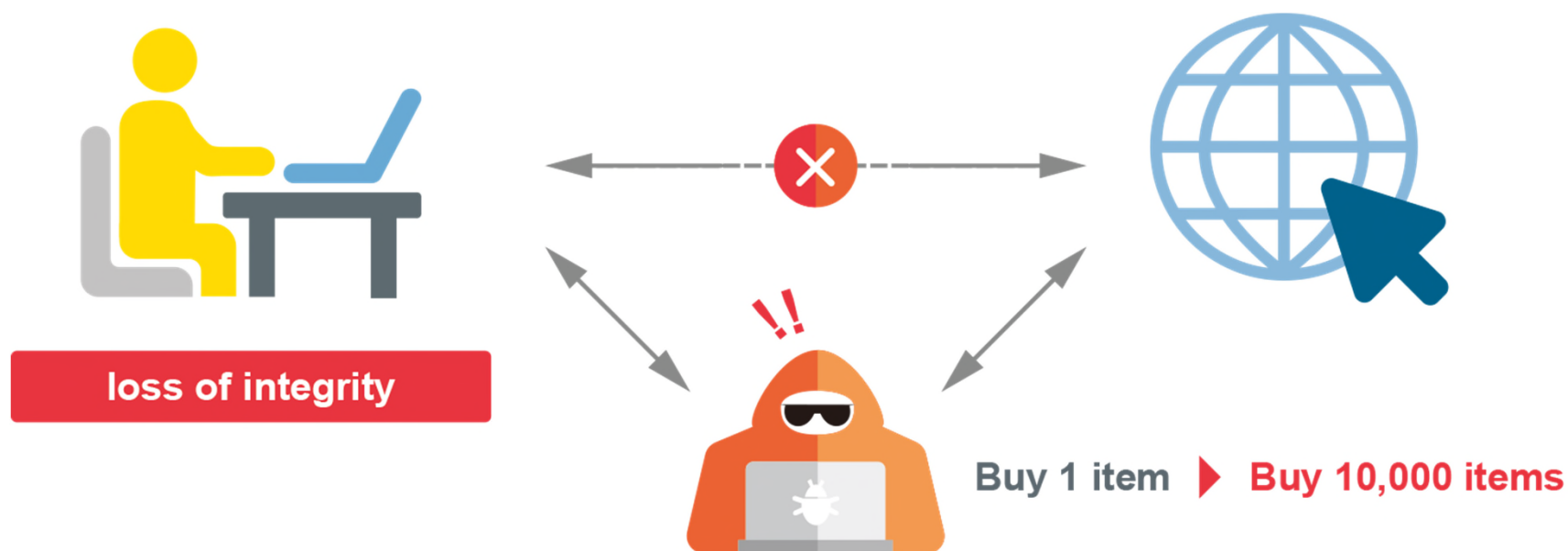
■ 完整性(Integrity)

- **意涵**：資料在其生命週期中持續正確、具一致性且可被信任

Data remains accurate, consistent, and trustworthy throughout its lifecycle

- **目標**：防止非授權人員竄改資訊，確保資訊正確性

- **解決方案**：資料驗證、數位簽章、完整性驗證等

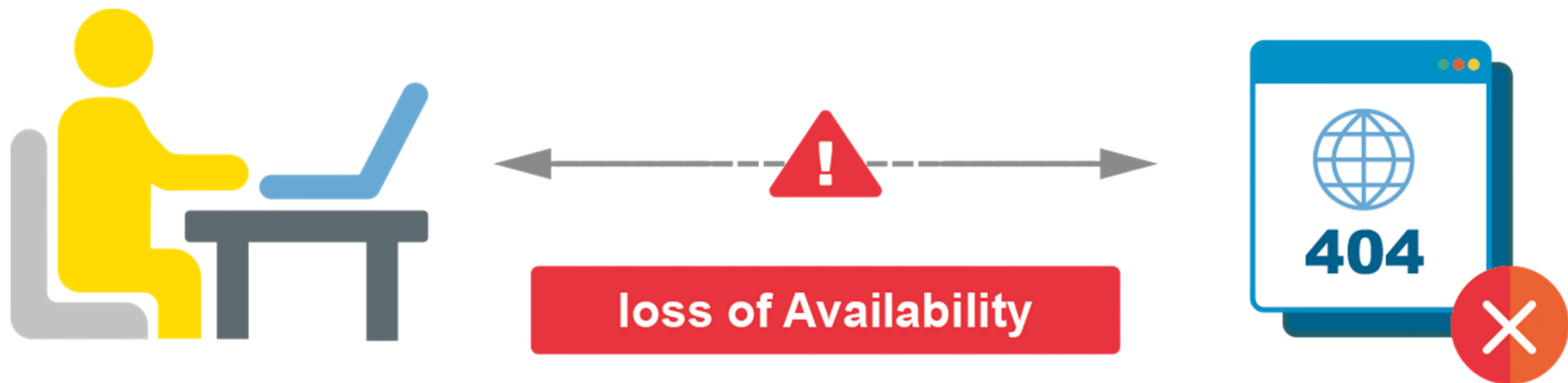




1-3 資通安全之目標(5/7)

■ 可用性(Availability)

- **意涵**：資訊與資源在需要時，可被存取與使用
Information and resources are accessible and usable when needed
- **目標**：防止系統故障或人為惡意阻斷服務，確保資訊與資訊處理的可獲得性
- **解決方案**：系統備援、系統監控等





1-3 資通安全之目標(6/7)

■ 法律遵循性(Legal compliance)

- 確保所欲保護的資訊內容，遵循法令法規要求。
- 重要相關法規

法規名稱：資通安全管理法
修正日期：114 年 9 月 24 日

法規名稱：資通安全管理法施行細則
修正日期：115 年 1 月 5 日

法規名稱：資通安全責任等級分級辦法
修正日期：115 年 1 月 7 日



法規名稱：個人資料保護法
修正日期：114 年 11 月 11 日

法規名稱：國家機密保護法
修正日期：112 年 12 月 27 日

其他業務相關法令法規要求，
如《人工智慧基本法》《醫事法》、
《兒童及少年福利與權益保障法》等



1-3 資通安全之目標(7/7)

■ C.I.A.保護之不同防護技術與方法

➤ 機密性保護

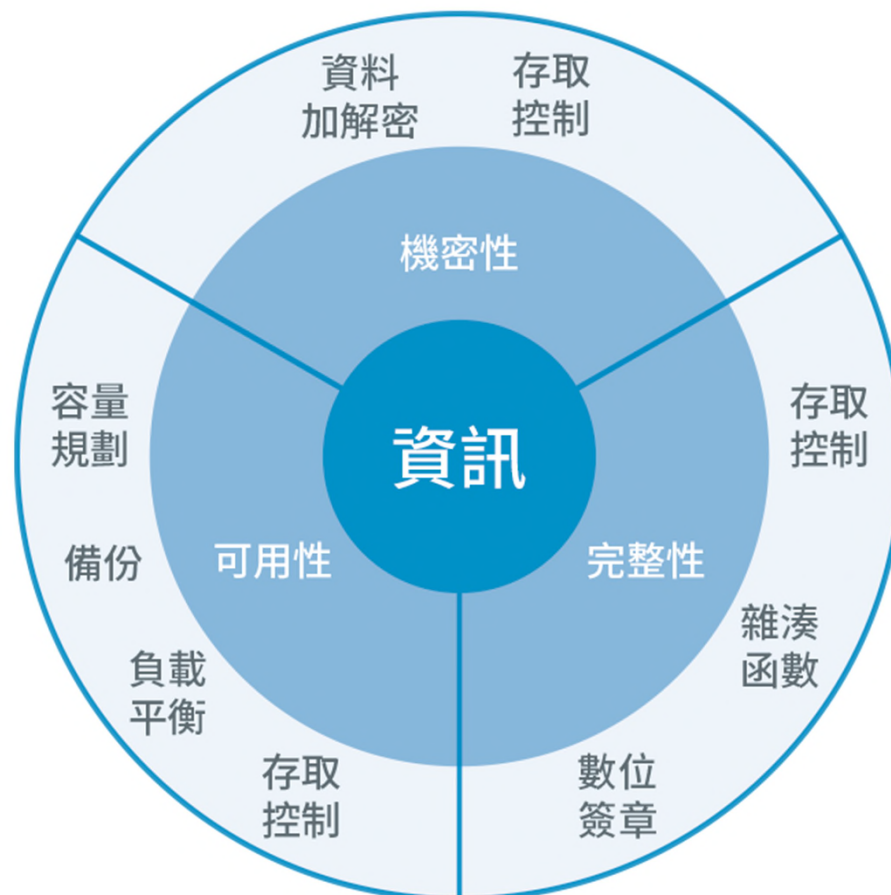
- 資料加解密
- 存取控制

➤ 完整性保護

- 雜湊函數
- 數位簽章
- 存取控制

➤ 可用性保護

- 容量規劃
- 備份
- 容錯、備援及負載平衡
- 存取控制



不同的安全性需求
使用不同的技術與方法



第2單元

資通安全相關法規



第2單元學習目標

- ✓ 2-1 了解資通安全管理法
- ✓ 2-2 了解資通安全管理法相關子法
- ✓ 2-3 了解其他相關法規



2-1 資通安全管理法(1/9)

■ 我國資通安全管理體系：§5

國家資通安全會報

召 集 人：行政院院長或副院長

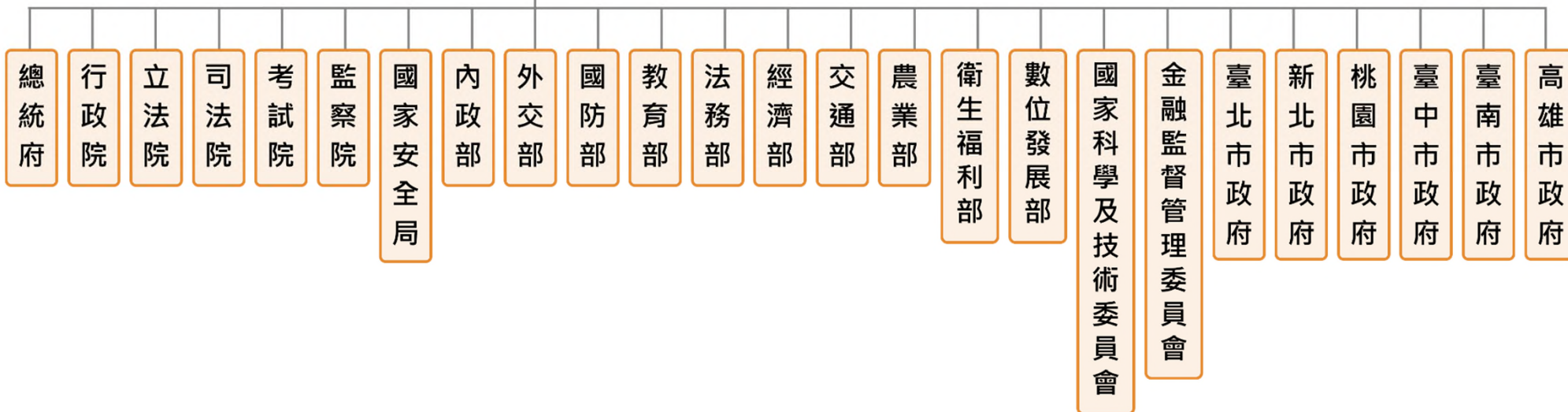
副 召 集 人：政務委員及主管機關首長

協同副召集人：國安會諮詢委員

數位發展部
(會報幕僚單位)

由資通安全署主政

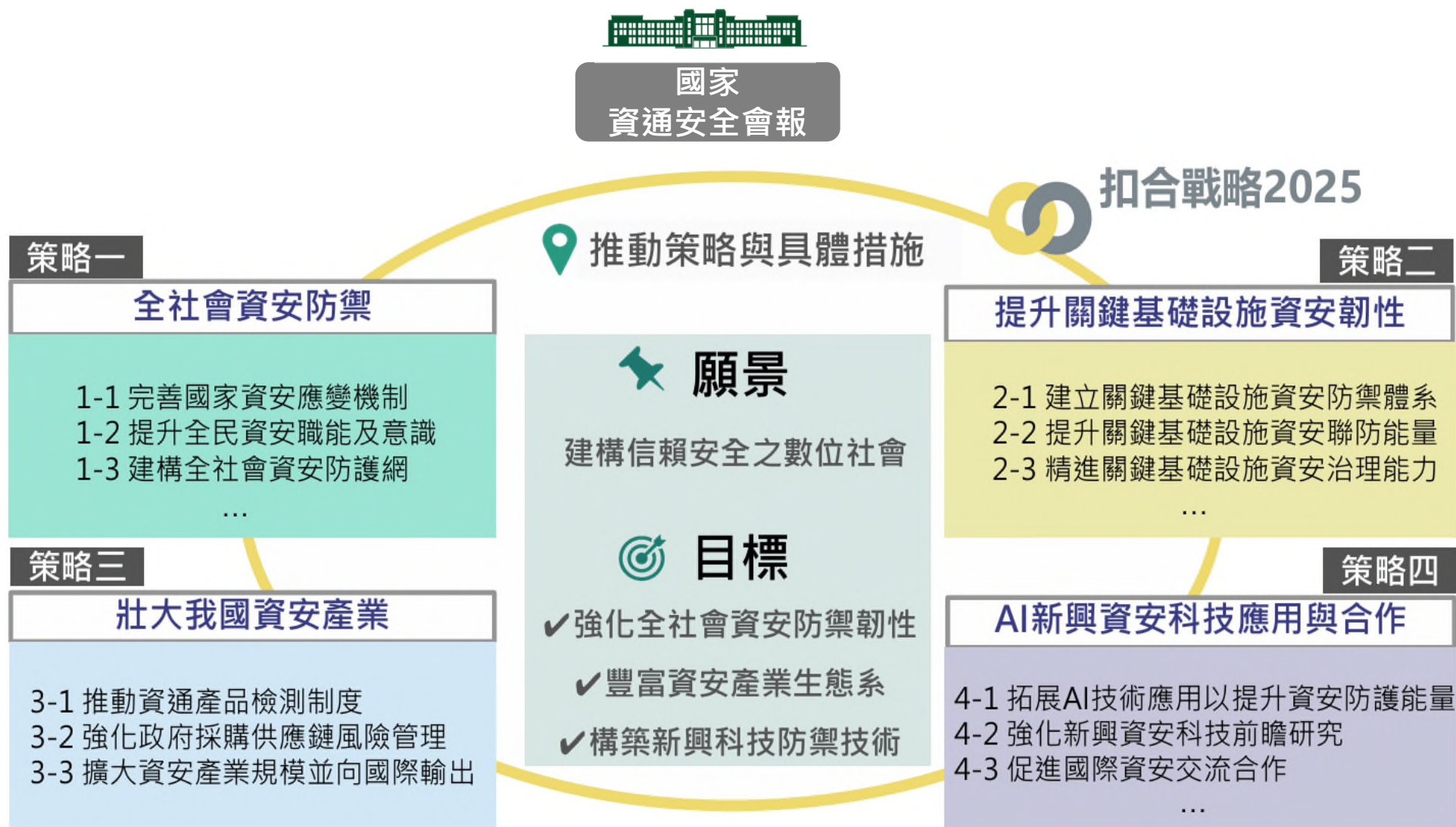
委員：下列機關之副首長或資通安全長





2-1 資通安全管理法(2/9)

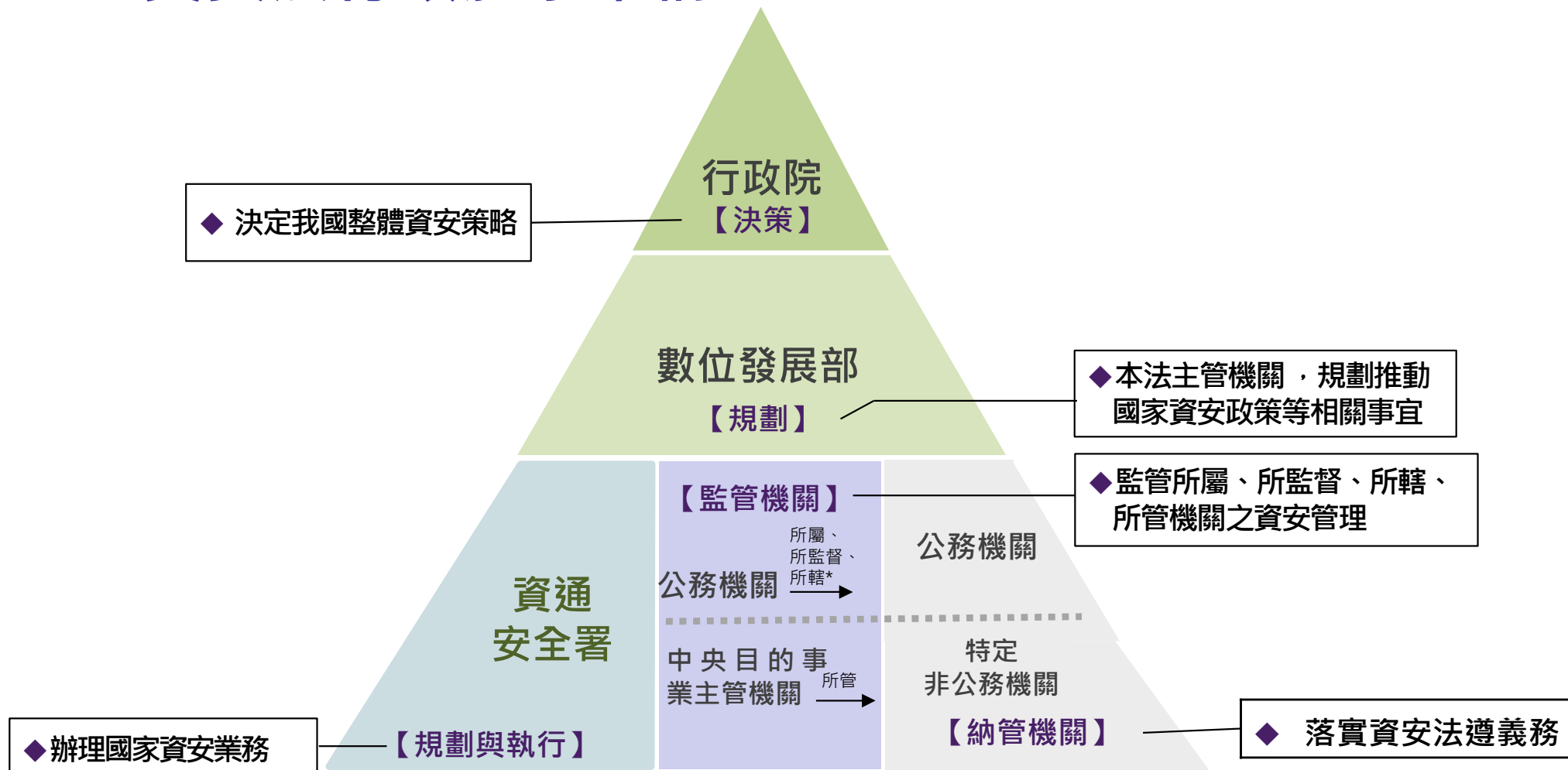
■ 第七期國家資通安全發展方案





2-1 資通安全管理法(3/9)

■ 資安法行政體系架構



➤ 【註】所轄公務機關：

- 在直轄市政府係指直轄市山地原住民區公所及直轄市山地原住民區民代表會；
- 在縣(市)政府係指鄉(鎮、市)公所、鄉(鎮、市)民代表會



2-1 資通安全管理法(4/9)

■ 資通安全管理法 - 條文摘要

114/9/24 修正；114/12/1 施行

第一章 總則

§1~§10

§1	1. 制定本法旨在推動國家資安政策。2. 目標為保障國家安全及維護公共利益。
§2	1. 主管機關變更為數位發展部。2. 數位發展部指定資安專責機關執行業務。
§3	1. 修正資通安全及事件定義(調整機密性/完整性/可用性影響文字)。2. 關鍵基礎設施及提供者之權責改由行政院管轄。3. 新增 「受政府控制之事業、團體或機構」定義。4. 新增 「危害國家資通安全產品」定義，指經主管機關認定，對國家資通安全具危害風險，影響政府運作或社會安定之資通系統、服務或產品。
§4	1. 政府應提供資源提升全民資安意識。2. 新增 「協助民間處理、因應及防範重大資安事件」。3. 發展方案報請行政院核定後實施。
§5	本條新增 ：1. 行政院應定期召開國家資通安全會報。2. 會報由行政院院長或副院長擔任召集人。3. 中央及地方應共同推動資安措施。
§6	1. 主管機關應規劃整體防護等事宜。2. 每年公布情勢報告、稽核概況報告及發展方案。3. 報告與方案應送立法院備查。
§7	1. 機關應報請主管機關核定或備查資安責任等級。2. 須符合等級要求並辦理管理、技術、認知及訓練等資安防護措施。
§8	1. 主管機關得定期或不定期稽核公務/特定非公務機關。2. 缺失應提改善報告。3. 稽核年度計畫須報請行政院核定。
§9	1. 應建立資通安全情資分享機制。2. 主管機關訂定情資分析、整合與分享等辦法。
§10	1. 委外應選任適當受託者並監督其資安管理。2. 受託者須具備完善措施或通過公正第三方驗證。3. 委外業務應簽訂書面契約。4. 應配合資安演練，得導入第三方協力機制。

第四章 罰則

§28~§31

§28	1. 公務機關人員未依規定辦理者應予懲戒或懲處。2. 新增 ：特定非公務機關所屬人員未依本法規定辦理，情節重大者，由該機關依規定予以懲處。
§29	特定非公務機關未通報資安事件，處罰鍰新臺幣三十萬至一千萬元(上限提高)，並令限期改正。
§30	特定非公務機關違反資安維護計畫、實施情形提出、改善報告、通報應變機制等規定，處罰鍰新臺幣十萬至五百萬元(上限提高)，並令限期改正。
§31	1. 新增 ：特定非公務機關違反第二十五條第三項規定，規避、妨礙或拒絕重大資安事件調查者，處罰鍰新臺幣十萬至一百萬元。

第五章 附則

§32~§35

§32	1. 主管機關得委託機關或法人辦理資安整體防護、演練、稽核等事務。2. 新增 ：特定非公務機關業務涉及數個中央目的事業主管機關時，主管機關得協調指定單獨或共同辦理本法所定事項。
§33	1. 新增 ：資通安全事件涉及個人資料外洩時，公務機關及特定非公務機關應另依個人資料保護法及其相關法令規定辦理。
§34	本法之施行細則，由主管機關定之。
§35	本法之施行日期，由行政院定之。



2-1 資通安全管理法(5/9)

■ 資通安全管理法 - 條文摘要

第二章公務機關資通安全管理

§11~§19

§11	本條新增： 1. 公務機關禁止使用危害國家資安產品。2. 例外專案使用須經資安長核可並報主管機關核定。3. 相關辦法由主管機關報請行政院核定。
§12	1. 公務機關應置資通安全長(副首長或適當人員兼任)。2. 負責推動及監督機關內資安事務。
§13	1. 公務機關須符合責任等級要求。2. 應訂定、修正及實施資通安全維護計畫。
§14	1. 公務機關每年向上級/監督機關提出資安計畫實施情形。2. 無上級者，分層向主管機關或地方政府提出。
§15	1. 公務機關應稽核所屬或監督機關之資安計畫實施情形。2. 新增： 地方政府對轄下區/鄉鎮市公所之稽核責任。
§16	1. 缺失改善報告須向稽核機關提出，並連同稽核結果送交主管機關。2. 稽核機關或主管機關得要求說明或調整。
§17	1. 應訂定資安事件通報及應變機制。2. 知悉事件應向受實施情形機關及主管機關通報。3. 應提出調查、處理及改善報告。4. 重大事件時，受通報機關得提供協助並公告。
§18	1. 應符合等級要求，設置資通安全專職人員。2. 績效優良者應予獎勵。3. 新增： 遇重大事件，主管機關得調度資安人員支援。
§19	本條新增： 1. 適任性進行查核。2. 查核未通過者，不得辦理涉國家機密之資安業務。3. 查核紀錄應保密處理。

第三章特定非公務機關資通安全管理

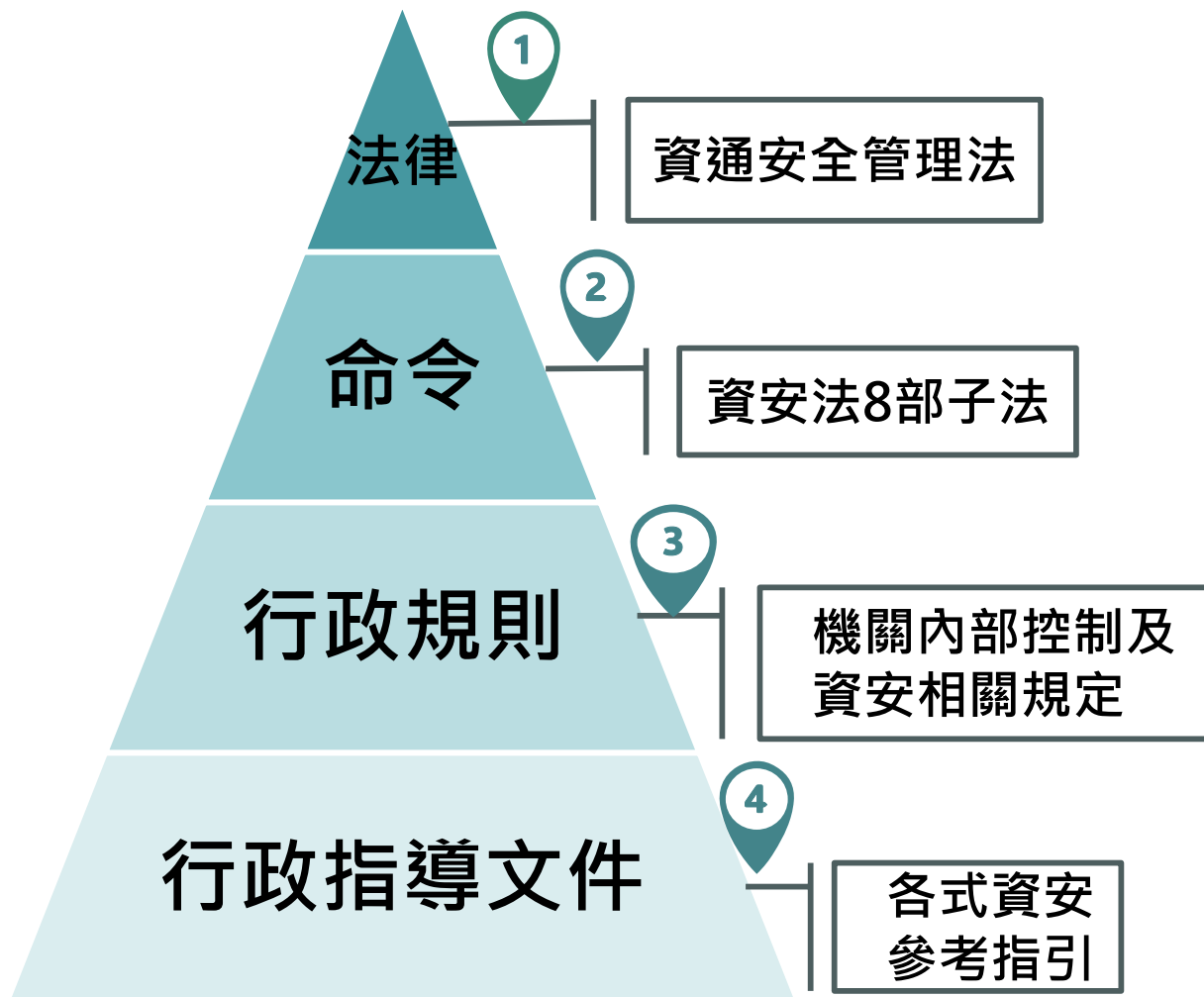
§20~§27

§20	1. 關鍵基礎設施提供者由中央目的事業主管機關指定，報請行政院核定。2. 新增： 資安專職人員。3. 中央目的事業主管機關應定期稽核。4. 稽核結果及改善報告送交主管機關。
§21	1. 關鍵基礎設施提供者以外之特定非公務機關， 新增： 資安專職人員。2. 中央目的事業主管機關得要求提出實施情形及得稽核。3. 稽核結果及改善報告送交主管機關。
§22	1. 本條由現行第十六條第六項及第十七條第四項合併修正移列。2. 授權中央目的事業主管機關擬訂維護計畫、稽核等辦法，報主管機關核定。
§23	本條新增： 1. 應設置資通安全長。2. 由代表人、管理人或指派人員擔任，負責監督資安事務。
§24	1. 應訂定資安事件通報及應變機制。2. 知悉應向中央目的事業主管機關通報。3. 重大事件報告應送交主管機關。4. 中央目的事業主管機關或主管機關得提供協助或公告。
§25	本條新增： 1. 重大資安事件，得行使調查權。2. 調查程序包括通知陳述、要求第三方報告或派員檢查。3. 當事人或關係人不得規避、妨礙或拒絕調查。
§26	本條新增： 特定非公務機關對於所屬人員辦理資通安全業務績效優良者，應予獎勵。
§27	本條新增： 1. 中央目的事業主管機關得限制或禁止特定非公務機關使用危害國家資安產品。2. 例外須經資安長核可，報中央目的事業主管機關核定。



2-1 資通安全管理法(6/9)

■ 我國資安法令規範層級



資安法相關8項子法

法令名稱
資通安全管理法施行細則
資通安全責任等級分級辦法
資通安全事件通報應變及演練辦法
資通安全維護計畫實施情形稽核辦法
資通安全情資分享辦法
公務機關所屬人員辦理資通安全事項作業辦法
危害國家資通安全產品審查辦法
國家資通安全會報設置辦法



2-2 資通安全管理法(7/9)

■ 立法目的

為積極推動國家資通安全政策，加速建構國家資通安全環境，以保障國家安全，維護社會公共利益

■ **主管機關**：數位發展部；資安專責機關：數位發展部資通安全署

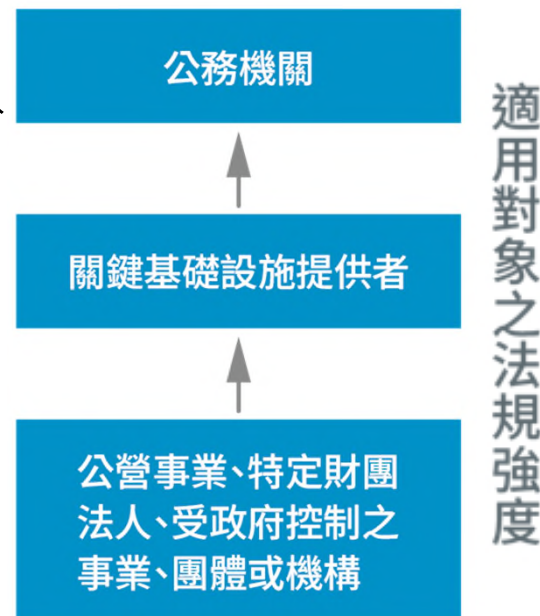
■ 適用對象

➤ 公務機關

- 指依法行使公權力之中央、地方機關(構)或公法人
- 但不包含軍事機關及情報機關

➤ 特定非公務機關

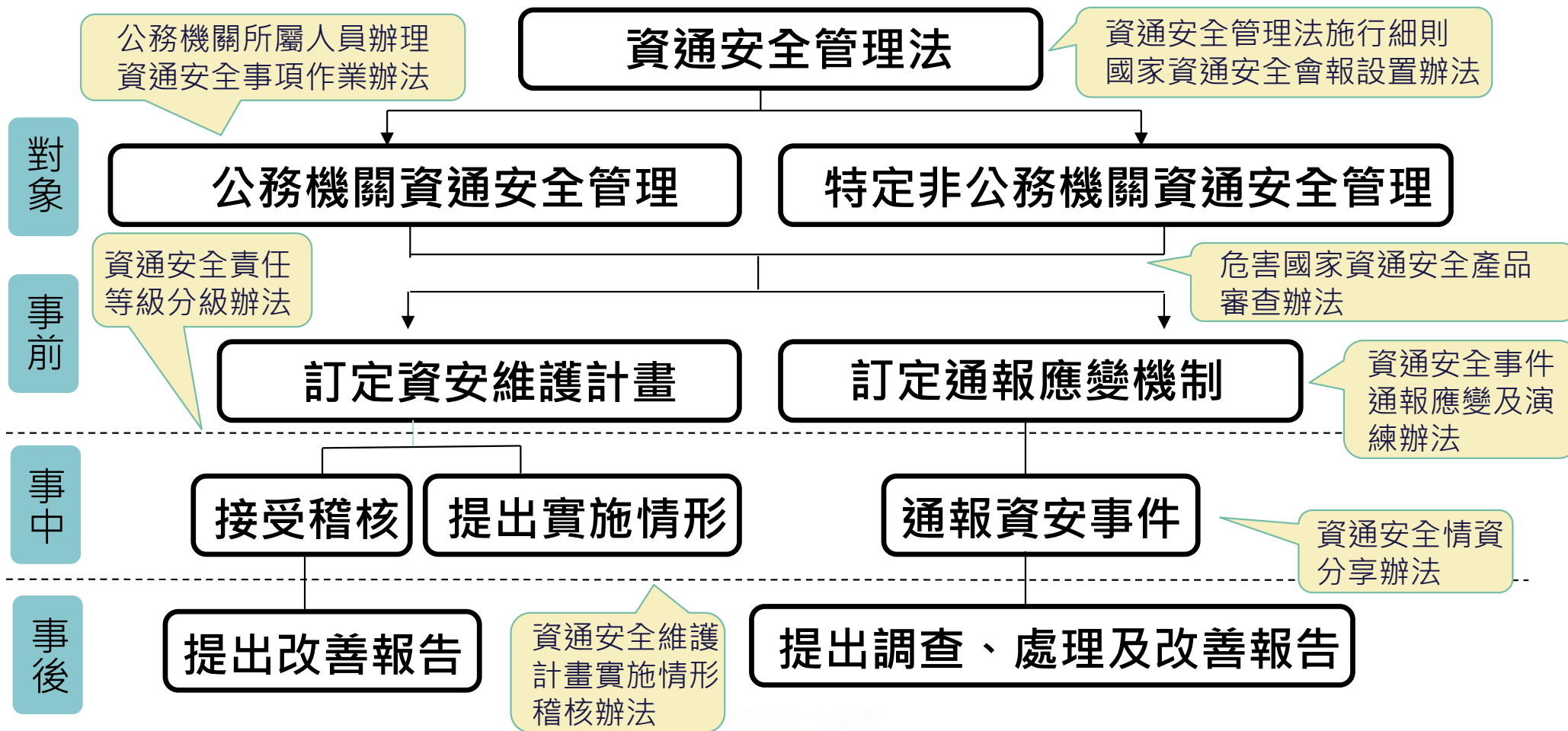
- 關鍵基礎設施提供者(例如:中油)
- 公營事業(例如:台糖)
- 特定財團法人(例如:工研院)
- 受政府控制之事業、團體或機構





2-1 資通安全管理法(8/9)

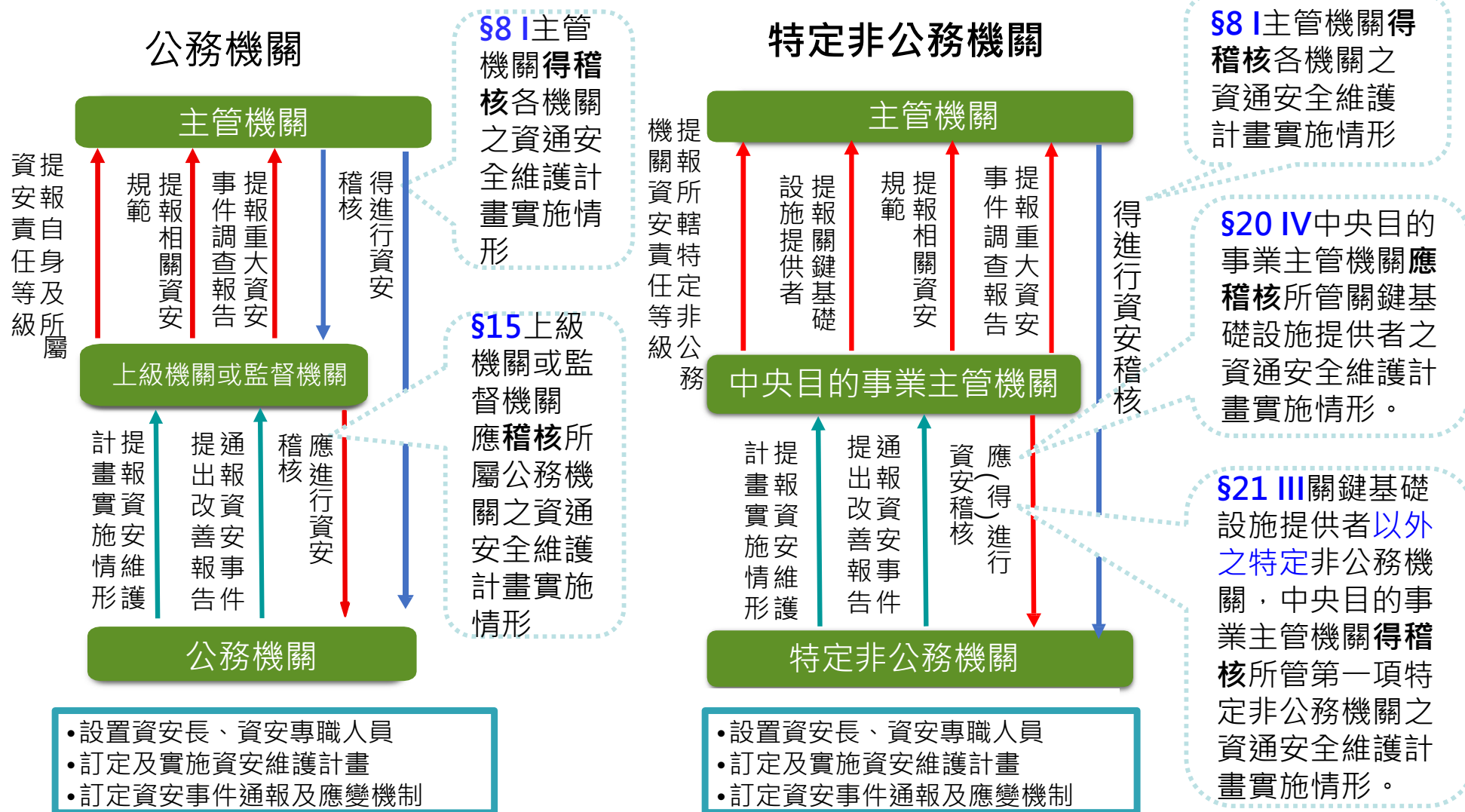
■ 資安管理生命週期 - 事前預防、事中應變、事後處理及改善





2-1 資通安全管理法(9/9)

■ 機關角色及權責





2-2 資通安全管理法相關子法(1/22)

■ 國家資通安全會報設置辦法 – 條文摘要 115/3/2 發布

§1 法源依據	→	資安法第5條
§2 會報任務	→	任務內容
§3 委員組成	→	組織成員與組成
§4 幕僚作業與執行秘書	→	每半年召開1次會議
§5 會議召開與出席	→	依業務需要設置
§6 專案小組設置	→	蒐整議題或協調工作
§7 幕僚工作會議	→	定期管考及績效評核
§8 給職與費用支領	→	依法自發布日施行
§9 經費支應	→	
§10 決議執行及績效評核	→	
§11 施行日期	→	



2-2 資通安全管理法相關子法(2/22)

■ 國家資通安全會報設置辦法

- **法源：**為建構我國資通安全整體環境，協調各**政府機關、中央及地方間**資通安全相關事務，健全我國整體資通安全管理，強化橫向溝通聯繫機制，將現行國家資通安全會報入法明文化，原「行政院國家資通安全會報設置要點」自行政規則提升至**法規命令**
- **理念：**資安法納管全國公務機關，資安推動工作面向廣泛，「聯防」已是國際趨勢，需要**跨院、跨部會機關、跨領域及公私協力**的合作。
- **會報成員：**總統府、行政院、立法院、司法院、考試院、監察院、國家安全局、所屬中央二級機關、各直轄市政府
- **會報任務：**
 - 國家資通安全政策之協調及推動。
 - 國家資通安全應變機制之協調及溝通。
 - 國家資通安全重大計畫之諮詢及審議。
 - 跨機關資通安全事務之協調及推動。
 - 資通安全工作辦理情形之督導及評核。
 - 其他有關國家資通安全業務之督導、協調及推動。



2-2 資通安全管理法相關子法(3/22)

■ 資通安全管理法施行細則 - 條文摘要

115/1/5 發布

§1：依據

§2：資通安全專責機關

§3：軍事及情報機關之定義

§4：受政府控制之事業、團體或機構於
指定前陳述意見之機會

§5：民間單位重大資安事件定義

§6：稽核結果改善報告之內容

§7：委外業務之選任監督與查核

§8：第三方協力機制之定義

§9：維護計畫及實施情形之內容

§10：核心業務之範圍

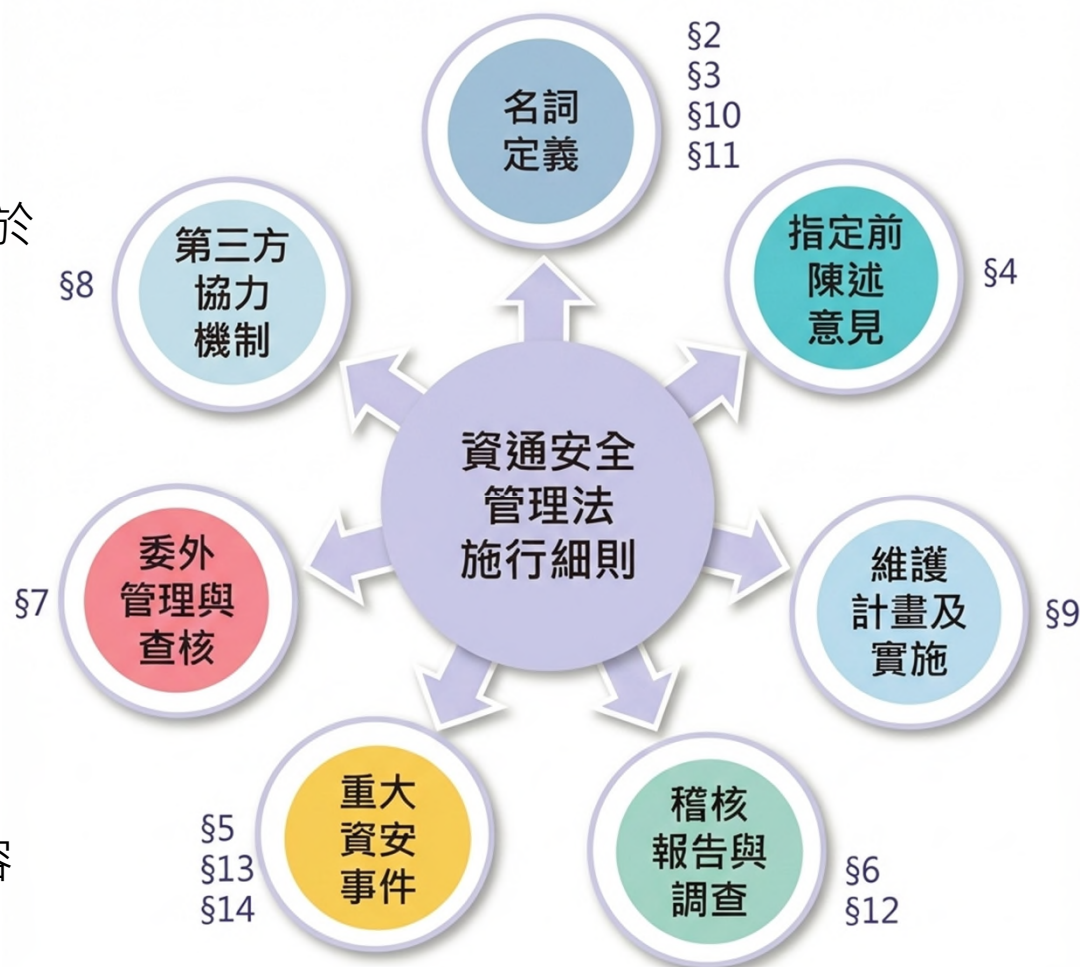
§11：核心資通系統與上級機關定義

§12：事件調查、處理及改善報告內容

§13：重大資通安全事件之等級界定

§14：重大資安事件之公告與例外

§15：自發布日施行





2-2 資通安全管理法相關子法(4/22)

■ 資通安全管理法施行細則 - §7 委外機關之適任性查核

- 受託業務涉及國家機密者，執行受託業務之相關人員應接受適任性查核，並依國家機密保護法之規定，管制其出境。
 - 曾犯刑法妨害電腦使用罪章之罪，經有罪判決確定，或通緝有案尚未結案
 - 曾犯洩密罪，或於動員戡亂時期終止後，犯內亂罪、外患罪，經判刑確定，或通緝有案尚未結案
 - 曾任公務員，因違反相關安全保密規定受懲戒或記過以上行政懲處
 - 曾受到外國政府、大陸地區、香港或澳門政府之利誘、脅迫，從事不利國家安全或重大利益情事
 - 其他與國家機密保護相關之具體項目

辦理適任性查核前，應經當事人書面同意



2-2 資通安全管理法相關子法(5/22)

■ 資通安全管理法施行細則 - §9 資通安全維護計畫

資通安全維護計畫	
1. 核心業務及其重要性	8. 資通安全防護及控制措施
2. 資通安全政策及目標	9. 資通安全事件通報、應變及演練相關機制
3. 資通安全推動組織	10. 資通安全情資之評估及因應機制
4. 專職人力及經費之配置	11. 資通系統或服務委外辦理之管理措施
5. 資通安全長之配置	12. 所屬人員辦理業務涉及資通安全事項之考核機制
6. 資通系統之盤點，並標示核心資通系統及相關資產	13. 資通安全維護計畫與實施情形之持續精進及績效管理機制
7. 資通安全風險管理	



2-2 資通安全管理法相關子法(6/22)

■ 資通安全管理法施行細則 - §10 核心業務及核心資通系統

第10條	內容
核心業務 範圍	公務機關依其組織法，足認該業務為機關核心職責所在。
	公營事業及政府捐助之財團法人之主要服務或功能。
	各機關維運、提供關鍵基礎設施所必要之業務。
	各機關依資通安全責任等級分級辦法第4條第1款至第5款或第5條第1款至第5款涉及之業務。(備註)
核心資通系統 定義	所稱核心資通系統，指支持核心業務持續運作必要之系統，或依資通安全責任等級分級辦法附表九資通系統防護需求分級原則之規定，判定其防護需求等級為高者。

備註：資通安全責任等級分級辦法

一、業務涉及國家機密。二、業務涉及外交、國防或國土安全事項。三、業務涉及全國性民眾服務或跨公務機關共用性資通系統之維運。四、業務涉及全國性民眾或公務員個人資料檔案之持有。五、屬公務機關，且業務涉及全國性之關鍵基礎設施事項。

§4 I~V

一、業務涉及公務機關捐助、資助或研發之國家核心科技資訊之安全維護及管理。二、業務涉及區域性、地區性民眾服務或跨公務機關共用性資通系統之維運。三、業務涉及區域性或地區性民眾個人資料檔案之持有。四、業務涉及中央二級機關及所屬各級機關（構）共用性資通系統之維運。五、屬公務機關，且業務涉及區域性或地區性之關鍵基礎設施事項。

§5 I~V



2-2 資通安全管理法相關子法(7/22)

■ 資通安全責任等級分級辦法 - 條文摘要

115/1/7 發布

§1：依據

§2：資通安全責任等級

§3：責任等級之核定、提交、備查、變更

§4：A級資通安全責任等級

§5：B級資通安全責任等級

§6：C級資通安全責任等級

§7：D級資通安全責任等級

§8：E級資通安全責任等級

§9：二個以上之資通安全責任等級者

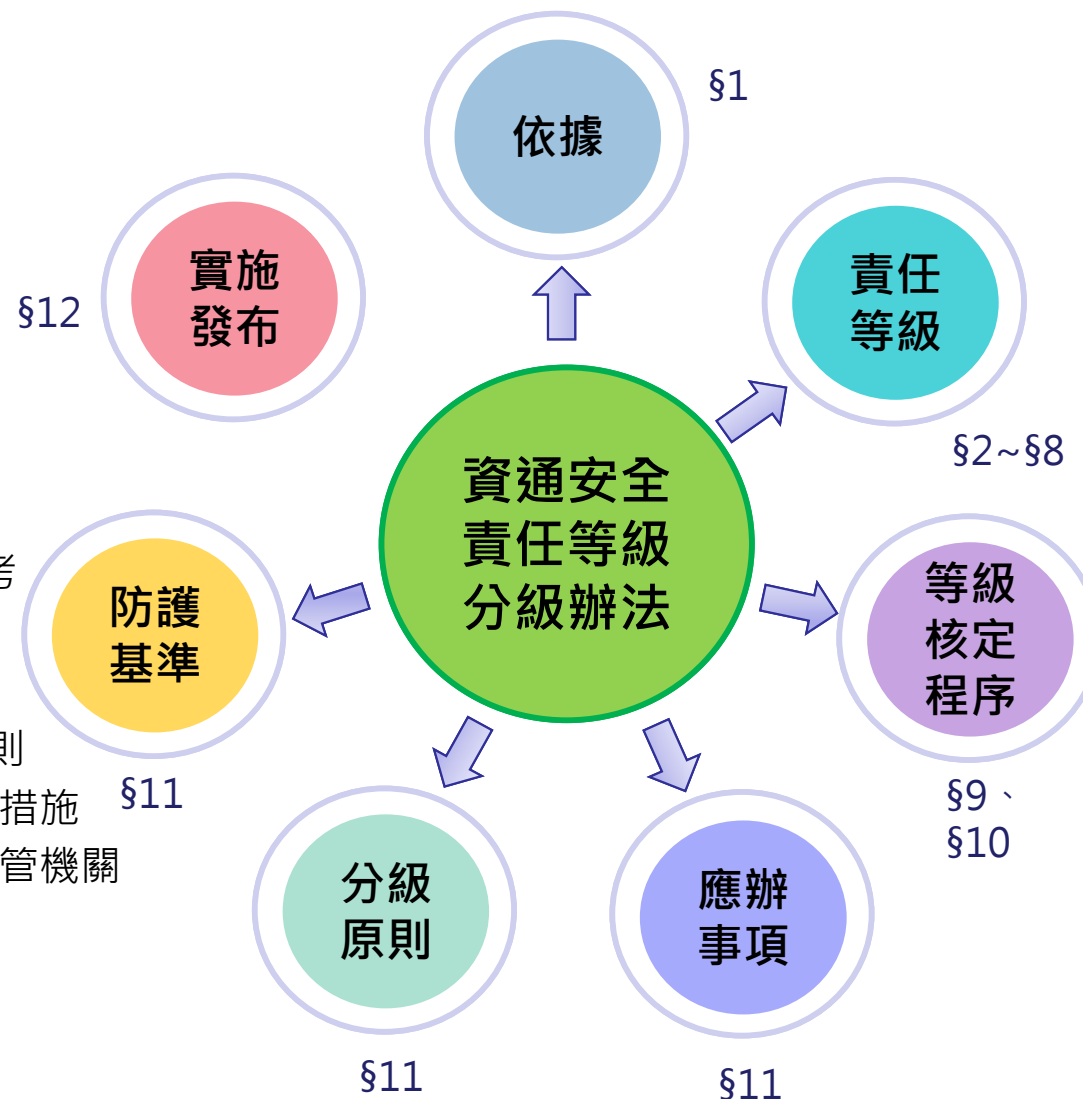
§10：提交或核定資通安全責任等級時，得考量事項

§11：資通安全責任等級應辦理事項(附表一至附表八)；資通系統防護需求分級原則(附表九)；資通系統防護基準執行控制措施(附表十)。各機關準用中央目的事業主管機關依前項所定防護基準相關規定辦理。

§12：施行日期及發布日

➤ 各機關應每3年提報或核定責任等級(§3)

➤ 各機關應依附表規定，辦理其資通安全責任等級應辦事項(§11)





2-2 資通安全管理法相關子法(8/22)

■ 資通安全責任等級分級辦法

➤ 準用防護基準 - 第11條第3項

- 公務機關經其上級機關或監督機關同意者，準用中央目的事業主管機關依前項所定防護基準相關規定辦理，**其他特定非公務機關**經其中央目的事業主管機關同意者，亦同

➤ 資安專職人員及資訊人員

- 資通安全專職人員：每人**每年**接受12小時以上之資通安全專業課程訓練或資通安全職能訓練
- 資安專職人員以外之資訊人員：每人**每2年**接受3小時以上之資通安全專業課程訓練或資通安全職能訓練，且**每年**接受3小時以上之資通安全通識教育訓練



2-2 資通安全管理法相關子法(9/22)

■ 資通安全維護計畫實施情形稽核辦法 - 條文摘要 115/1/5 發布

§1：依據

§2：維護計畫辦理與情形提出

§3：系統平臺提出實施情形

§4：收受實施情形之公務機關訂定稽核計畫

§5：主管機關得稽核各機關維護計畫實施情形

§6：受稽核機關遴選與計畫內容

§7：稽核通知與日期調整

§8：稽核執行與配合義務

§9：稽核小組之組成與迴避

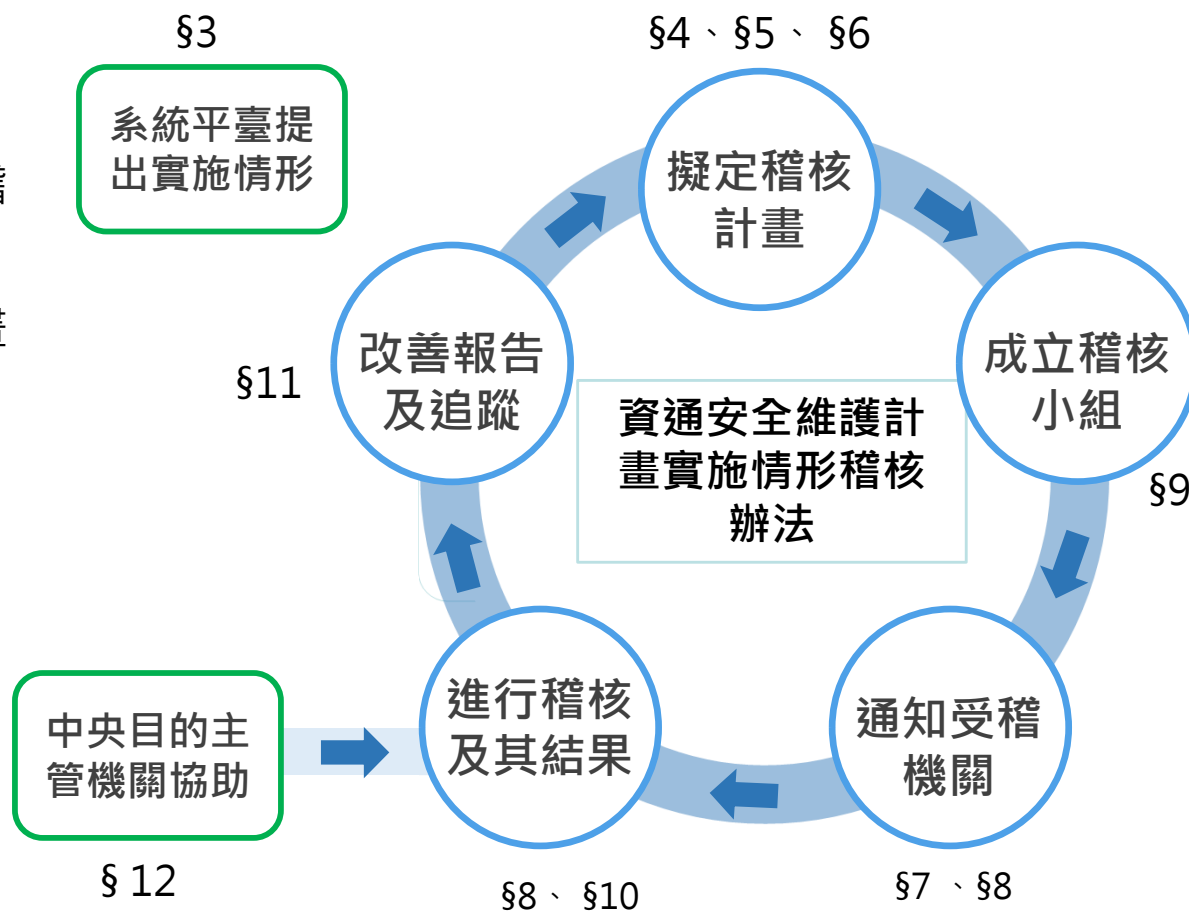
§10：稽核結果報告之交付

§11：改善報告與追蹤

§12：主管機關稽核之協助

§13：稽核作業得委任

§14：自發布日施行





2-2 資通安全管理法相關子法(10/22)

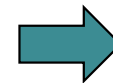
■ 資通安全維護計畫實施情形稽核辦法

- 本法第15條規定收受資通安全維護計畫實施情形之公務機關，對其所屬、所監督之公務機關、所轄鄉(鎮、市)公所、直轄市山地原住民區公所及鄉(鎮、市)民代表會、直轄市山地原住民區民代表會之資通安全維護計畫實施情形，應每年訂定稽核計畫，並掌握稽核情形。
- 稽核計畫，其內容至少包括下列事項：

- 稽核依據
- 稽核目的
- 稽核範圍
- 作業期程
- 稽核小組組成方式
- 保密義務
- 受稽核機關遴選原則
- 稽核基準
- 稽核方式及項目

主管機關

得稽核



本法§8

- 所有公務機關
- 所有特定非公務機關

公務機關

應稽核



本法§15

- 所屬/所監督之公務機關
- 直轄市山地原住民區公所/區民代表會
- 鄉(鎮、市)公所/鄉(鎮、市)民代表會

中央目的事業
主管機關

應稽核

本法§20



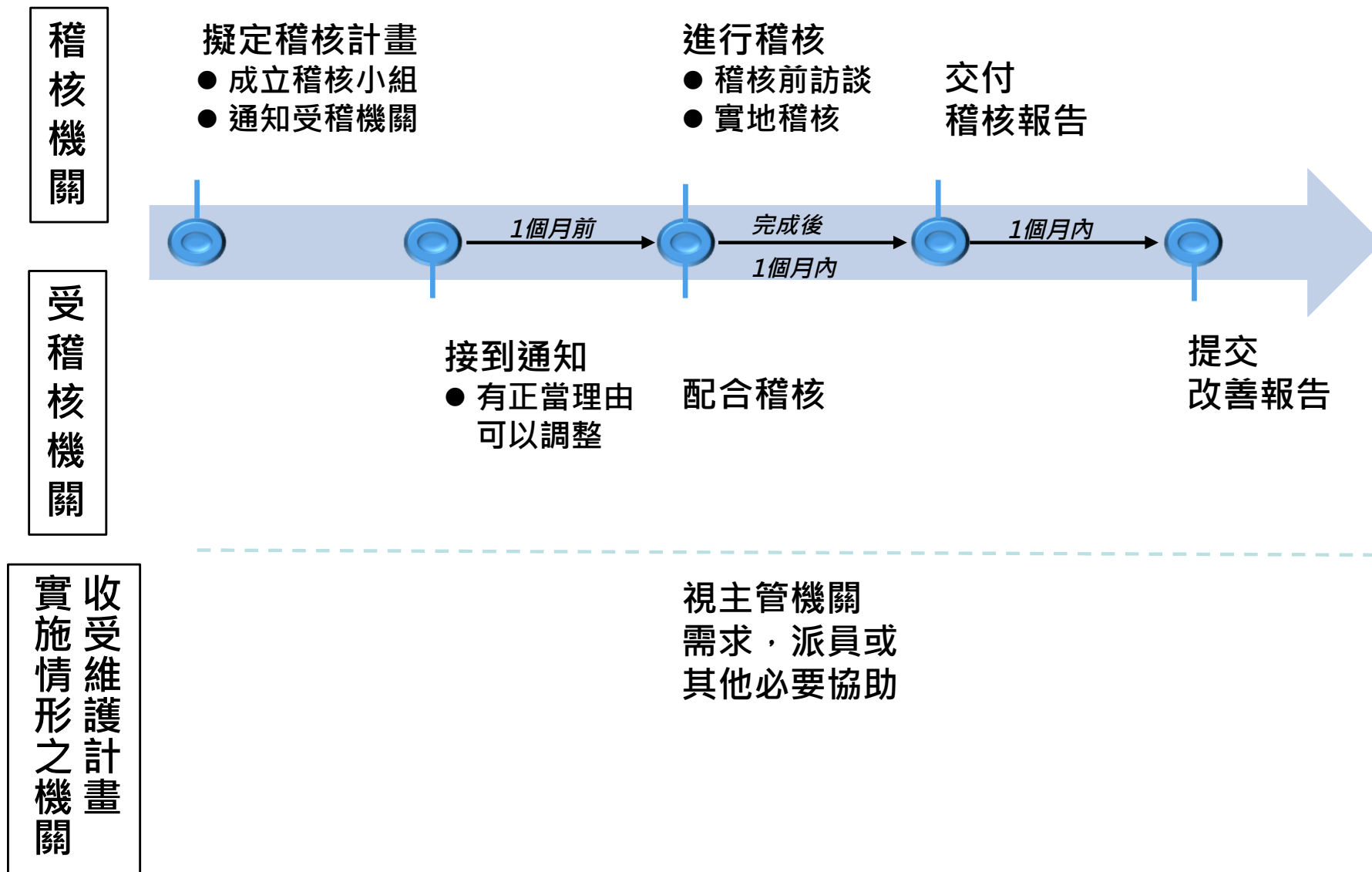
得稽核
本法§21

- 關鍵基礎設施提供者
- 其他特定非公務機關



2-2 資通安全管理法相關子法(11/22)

■ 資通安全維護計畫實施情形稽核辦法 - 稽核時程





2-2 資通安全管理法相關子法(12/22)

■ 資通安全事件通報應變及演練辦法 - 條文摘要 115/1/5 發布

第一章 總則(§1~§5)

§1依據、§2資安事件分為4級、§3資安事件通報內容、§4訂定通報作業規範及內容、§5訂定應變作業規範及內容

第二章 公務機關資通安全事件之通報應變及演練(§6~§10)

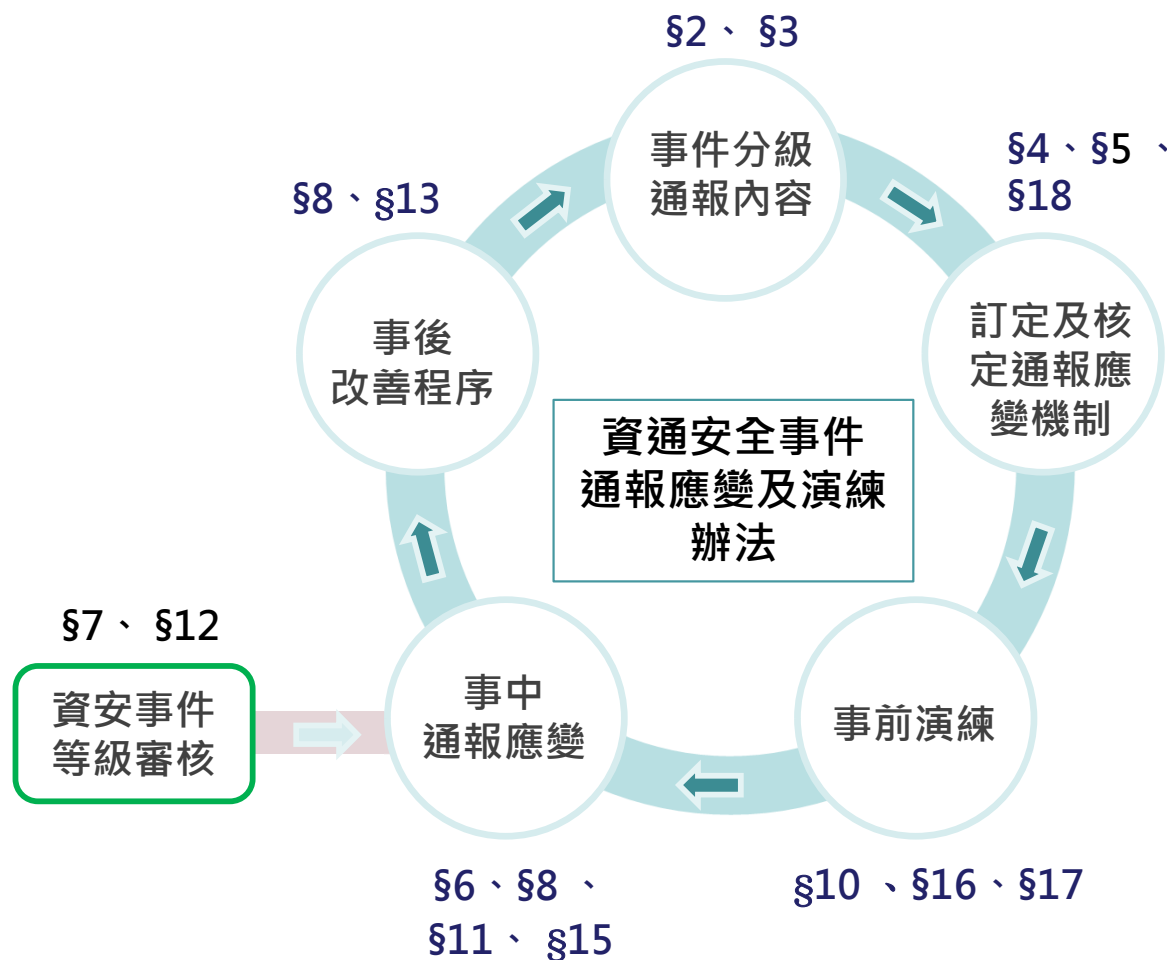
§6知悉通報系統平台、§7審核等級及時限、§8損害復原時限及報告、§9支援及協助、§10訂定演練作業

第三章 特定非公務機關資通安全事件之通報及應變(§11~§14)

§11知悉通報、§12審核等級及時限、§13損害復原時限及報告、§14支援及協助

第四章 附則(§15 ~ §20)

§15主管機關得召開會議時機、§16公務機關及特定非公務機關配合資通安全演練作業、§17演練作業應予保密、§18通報及應變機制之核定、§19主管機關得委任數位發展部資通安全署辦理本辦法事項、§20自發布日施行





2-2 資通安全管理法相關子法(13/22)

■ 資通安全事件通報應變及演練辦法 - 修正重點

- **目的：**配合資通安全管理法部分條文內容修正及因應實務運作所需，修正本辦法。
- **修正重點：**
 - **修正：**中央目的事業主管機關送交資通安全事件之審核結果、依據及其他必要資訊之方式，均於審核完成後1小時內，依主管機關指定之方式送交主管機關。
 - **增加：**公務機關應配合上級機關或監督機關規劃、辦理之資通安全演練作業；特定非公務機關應配中央目的事業主管機關規劃、辦理之資通安全演練作業
 - **增加：**演練作業相關參與人員知悉機敏資訊應負有保密義務



2-2 資通安全管理法相關子法(14/22)

■ 資通安全情資分享辦法 - 條文摘要

115/1/5 發布

§1：依據

§2：資通安全情資內容之定義

§3：情資應互相分享及獎勵

§4：情資不得分享之情形

§5：情資分享前，應先分析整合及規劃安全維護措施

§6：接收情資後，應辨識及研判風險並採取之預防或應變措施

§7：接收情資後，得關聯分析，並分享新威脅情資。

§8：接收情資後，應採取安全維護措施

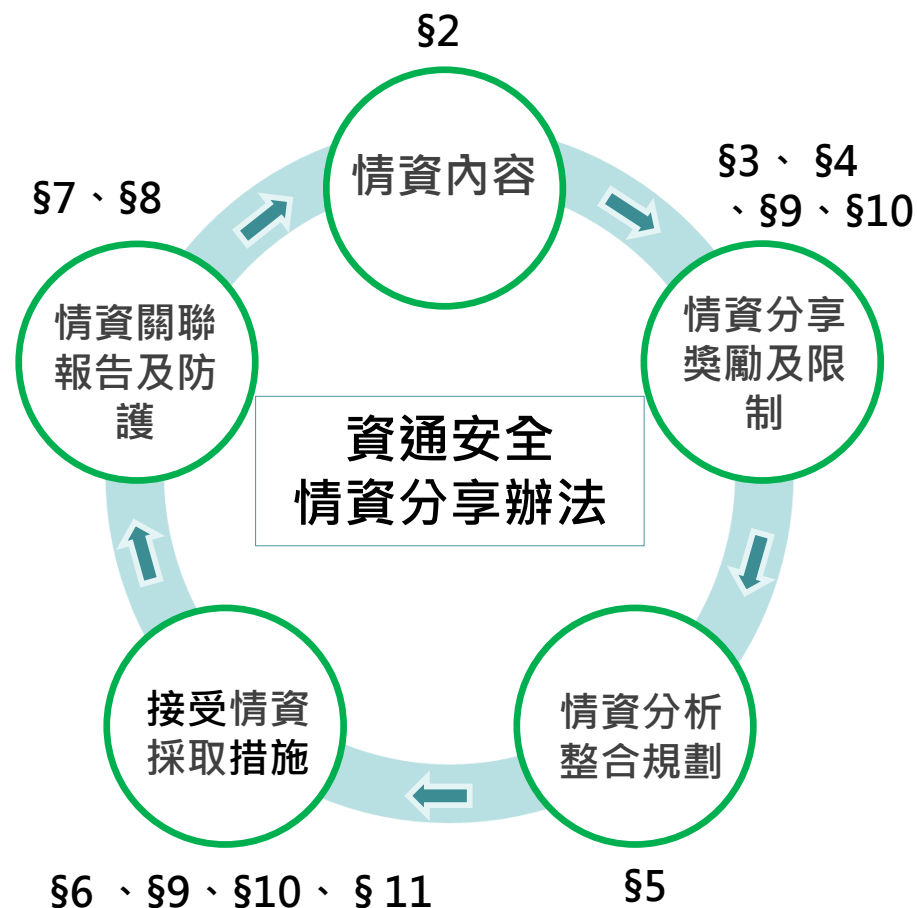
§9：情資分享之指定方式

§10：民間單位參與情資分享之機制

§11：有危害資安疑慮之處理

§12：主管機關得委任數位發展部資通安全署辦理本辦法事項

§13：自發布日施行





2-2 資通安全管理法相關子法(15/22)



■ 資通安全情資分享辦法 - 修正重點

➤ **目的：**因應資通安全管理法增訂危害國家資通安全產品之情資分享機制，將危害國家資通安全產品增列為資通安全情資，後續依本辦法規定進行情資分享

➤ **修正重點：**

第2條 本辦法所稱資通安全情資，指包括下列任一款內容之資訊：

- 一、資通系統之惡意偵察或情蒐活動
- 二、資通系統之安全漏洞
- 三、使資通系統安全控制措施無效或利用安全漏洞之方法
- 四、與惡意程式相關之資訊
- 五、資通安全事件造成之實際損害或可能產生之負面影響
- 六、用以偵測、預防或因應前五款情形，或降低其損害之相關措施
- 七、本法第三條第十一款所定之危害國家資通安全產品
- 八、其他與資通安全事件相關之技術性資訊



2-2 資通安全管理法相關子法(16/22)

■ 資通安全情資分享辦法 - 修正重點

- **目的：**分享之情資足以防止其他機關資通安全事件之發生或降低其損害者，擴增獎勵範圍
 - **修正重點：**分享之情資，經主管機關或中央目的事業主管機關認定足以防止其他機關資通安全事件之發生或降低其損害者，主管機關或中央目的事業主管機關得予以獎勵 (§3)
-
- **目的：**為掌握各機關確實應處情資之情形，提升情資分享效益，並配合現行情資應處實務執行方式，將情資回報義務明確化
 - **修正重點：**主管機關或中央目的事業主管機關得就指定之情資，通知接收情資之機關回報前項措施 (§6)



2-2 資通安全管理法相關子法(17/22)

■ 公務機關所屬人員辦理資通安全事項作業辦法 - 條文摘要

115/1/13 發布

➤ 第一章 總則

§1：依據

§2：資通安全人員及專職人員定義

➤ 第二章 適任性查核

§3：資通安全專職人員情形及錄取人員定義

§4：適任性查核項目及查核程序

§5：法務部調查局辦理及知會當事人

§6：當事人陳述意見、申辯及重行查核

§7：代理專職人員準用適任性查核規定

➤ 第三章 資通安全職能訓練

§8：資通安全職能訓練辦理事項

§9：資安職能訓練證書核發及撤銷

➤ 第四章 調度支援

§10：建置資通安全人員名冊、專長及經驗

§11：調度支援之啟動時機

§12：調度支援內容

§13：調度支援決定

§14：調度支援事先徵詢意見及配合指揮調度

§15：通知支援機關及事件發生機關應記載事項

§16：參與調度支援人員應配合作成紀錄

§17：參與調度支援人員負保密義務

➤ 第五章 獎懲作業

§18：自行訂定資通安全事項之獎懲基準

§19：13項獎勵情形

§20：4項懲處情形

§21：平時考核應審酌獎勵及懲處情形

§22：懲處前應給予當事人申辯機會

§23：主管機關得委任數位發展部資通安全署辦理本辦法事項

§24：自發布日施行



2-2 資通安全管理法相關子法(18/22)

■ 公務機關所屬人員辦理資通安全事項作業辦法 - 修正重點



人員定義與適任性查核

- **適用對象：**含「資安專職人員」及「實際從事資安業務者」
- **查核機制：**涉及國家機密或經審認有必要者，應函請法務部調查局進行查核
- **不予任用：**未通過查核者不得辦理涉敏業務；當事人可於 15 日內提出申辯，或依法提起救濟



職能訓練與證照

- **制度規劃：**由主管機關統籌職能訓練制度、教材開發及訓練機構遴選
- **證書核發：**評量合格者核發資安職能證書。
- **撤銷規定：**若發現舞弊或違規情事，將撤銷已發之證書



重大事件調度支援

- **維護人員名冊：**各機關應定期維護資安人員名冊，並標註專長
- **啟動時機：**發生重大資安事件時，由主管機關依規模與需求決定啟動
- **支援期限：**每次以7日為限，必要時得延長一次(最長7日)
- **人員義務：**支援期間須配合指揮，並對機敏資訊負完全保密義務



考核獎懲與附則

- **獎勵事由：**績效優良、防止事件發生、主動發現弱點等 13 項
- **懲處事由：**未落實資安計畫、通報應變不力等情節重大者。
- **程序保障：**獎懲納入平時考核；懲處前應給予當事人陳述意見機會
- **權責委任：**相關事項得委任數位發展部資通安全署辦理



2-2 資通安全管理法相關子法(19/22)

■ 危害國家資通安全產品審查辦法 - 條文摘要 114/12/1 施行

§1：依據

§2：提報之資格及程序

§3：審查作業風險評估

§4：審查程序

§5：危害產品情資分享之對象

§6：接收§5後應採取之措施

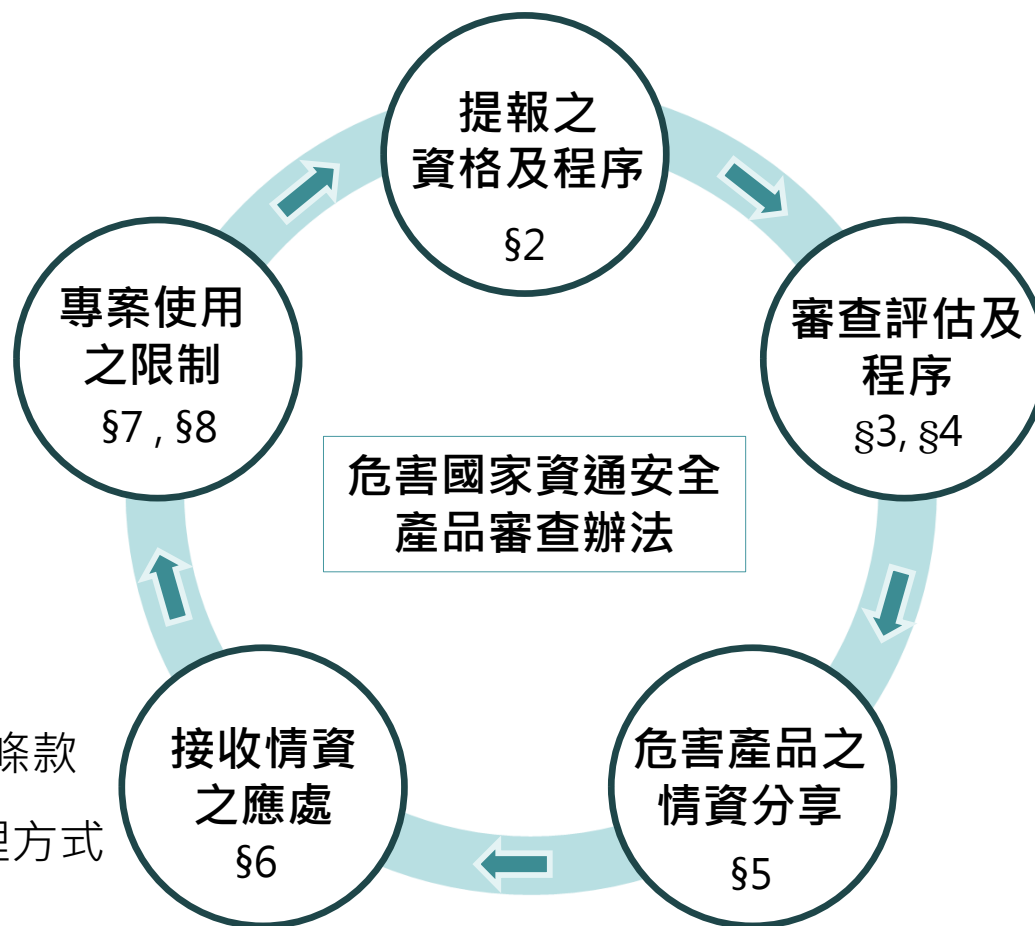
§7：專案使用危害產品應採取措施

§8：參與審查人員之保密規定

§9：本辦法施行前已申請專案使用之過渡條款

§10：審查過程中發現資通安全情資之辦理方式

§11：自114年12月1日起施行

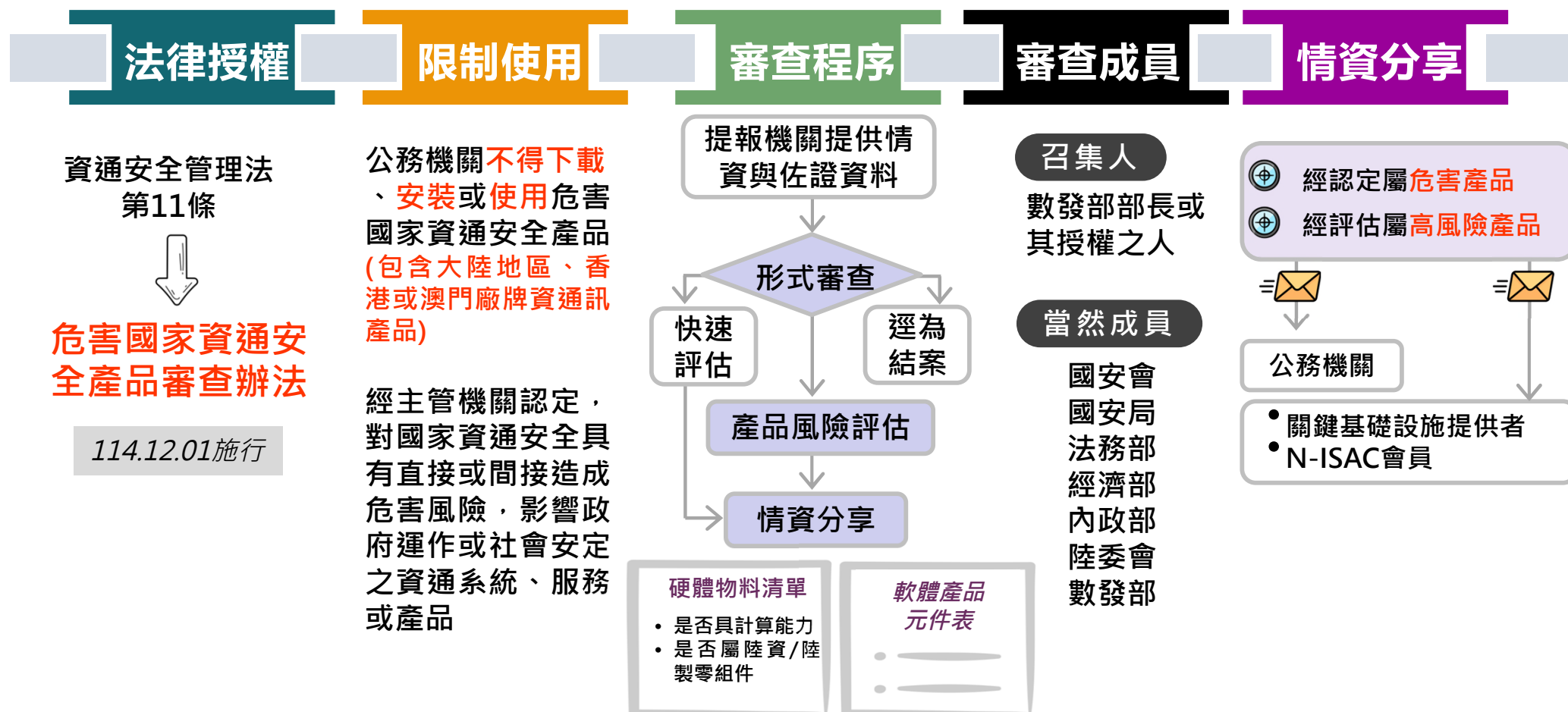




2-2 資通安全管理法相關子法(21/22)

■ 危害國家資通安全產品審查辦法

➤ 危害產品之限制、審查及分享程序





2-2 資通安全管理法相關子法(22/22)

■ 危害國家資通安全產品審查辦法

➤ 提報機關及提報表

提報機關：公務機關及特定非公務機關對於資通系統、服務或產品，認有危害國家資通安全之疑慮時，應依規定填具提報表並檢附相關文件送交主管機關審查

◆ 公務機關：由各該機關提報

- 一、總統府、國家安全會議、五院及其直屬機關
- 二、中央二級機關所屬或所監督之公務機關
- 三、直轄市政府、直轄市議會、縣(市)政府及縣(市)議會
- 四、直轄市、縣(市)政府所屬、所監督之公務機關，與所轄鄉(鎮、市)公所、直轄市山地原住民區公所、鄉(鎮、市)民代表會及直轄市山地原住民區民代表會及其所屬或所監督之公務機關

◆ 特定非公務機關：由其中央目的事業主管機關提報

➤ 提報表效益

- ◆ 機關了解風險來源可能，提升機關識別風險能力。
- ◆ 同一部會各機關使用產品通常來源相同，使上級機關提前掌握所屬各機關之潛在風險，提高機關縱向資安聯防效率。



2-3 其他相關法規(1/7)



■ 國家機密保護法(1/2)

92/2/6公布、92/10/1施行、112/12/27修正

➤ 國家機密之定義

- 為確保國家安全或利益而有保密之必要
- 對政府機關持有或保管之資訊，經依本法核定機密等級者

➤ 國家機密之範圍如下

- 軍事計畫、武器系統或軍事行動
- 外國政府之國防、政治或經濟資訊
- 情報組織與其活動
- 政府通信、資訊之保密技術、設備或設施
- 外交或大陸事務
- 科技或經濟事務
- 其他為確保國家安全或利益而有保密之必要者



2-3 其他相關法規(2/7)

■ 國家機密保護法(2/2)

➤ 國家機密等級區分為

- 「絕對機密」、「極機密」及「機密」三個等級

➤ 國家機密之核定原則

- 應在必要之「最小範圍內」為之
- 處理應屬國家機密之事項時，應按其機密程度擬訂等級，先行採取保密措施，並即報請核定；有核定權責人員，應於接獲報請後30日內完成核定
- 核定國家機密等級時，應併予核定其保密期限或解除機密之條件

➤ 國家機密之保密期限

- 絕對機密：不得逾30年；極機密：不得逾20年；機密：不得逾10年
- 取消永久保密期限之檔案：112年本法修正後，原依本法核定永久保密之國家機密，應於第12條修正施行之日起2年內，依本法重新核定，其保密期限溯自原先核定之日起算；屆滿2年尚未重新核定者，自屆滿之日起，視為解除機密。
- 國家機密變更機密等級者，其保密期限仍自原核定日起算



2-3 其他相關法規(3/7)

■ 個人資料保護法

99/5/26公布，101/10/1施行，114/11/11修正

➤ 目的

- 為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用

➤ 個人資料(限定於「自然人」)

- 屬性資料，例如：姓名、生日及身分證字號等
- 行為資料，例如：健康檢查與犯罪前科等
- 其他得以直接或間接方式識別該個人之資料

➤ 規範行為

- 當事人個人資料自主權利不得預先拋棄
- 特定目的之蒐集、處理或利用
- 明確告知蒐集之目的、個人資料類別、其使用範圍及資料來源
- 保持正確與蒐集目的消失後刪除義務



2-3 其他相關法規(4/7)

■ 個人資料保護法與資通安全管理法比較

項目	資通安全管理法	個人資料保護法
主管機關	數位發展部	個人資料保護委員會
立法目的	為積極推動國家資通安全政策，加速建構國家資通安全環境，以保障國家安全，維護社會公共利益	為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用
適用對象	公務機關及特定非公務機關	於任何「公務機關」與「非公務機關」(公務機關以外之自然人、法人或其他團體)。因此，無論是公司、獨資、合夥、自然人、負責人等為個人資料保護法規範之對象
主要重點	著重納管機關之資安管理作業，並降低資安風險	著重個人資料的保護，限制個資外洩與不當使用



2-3 其他相關法規(5/7)

■ 人工智慧基本法

115/1/14公布及施行

➤ 基本原則與定義 (§1~§4)

- **主管機關**：中央為國家科學及技術委員會；地方為直轄市、縣(市)政府 (§2)
- **AI 定義**：指具自主運行能力之系統，透過機器學習及演算法，能產出預測、內容、建議或決策 (§3)
- **七大原則**：(1) 永續發展 (環境與福祉)、(2) 人類自主 (尊重人權、可監督)、(3) 隱私治理 (資料最小化)、(4) 資安防護 (系統穩健性)、(5) 透明可釋 (產出標記、風險揭露)、(6) 公平不歧視 (避免演算法偏差)、(7) 問責機制 (內部治理與外部責任) (§4)

➤ 推動機制與激勵 (§6~§12)

- **組織戰略**：成立「國家人工智慧戰略特別委員會」，由行政院長召集，負責訂定國家發展綱領 (§6)
- **教育與人才**：推動學校及公務體系之 AI 倫理教育；促進產官學跨域人才交流 (§7~§8)



2-3 其他相關法規(6/7)

■ 人工智慧基本法

➤ 推動機制與激勵(續) (§6~§12)

- 資源與激勵：財政支持；創新實驗；成效評估 (§9~§11)
- 國際連結：推動國際合作，採公私協力模式接軌全球 (§12)

➤ 社會保障與風險管理 (§5 、§13~§17)

- 風險分級：數位發展部推動風險分類框架，各部會據此訂定管理規範 (§16)；高風險應用須明確標示警語或注意事項 (§5)
- 責任與救濟：明確高風險應用之責任歸屬；建立補償、救濟或保險機制 (§17)
- 勞動權益：運用 AI 確保勞權、弭平技能落差；針對因 AI 失業者提供輔導協助 (§15)
- 資料治理：落實「預設隱私」；建立資料開放機制，同時維護智財權與多元價值 (§13~§14)



2-3 其他相關法規(7/7)

■ 人工智慧基本法

➤ 法規調整與政府使用 (§18~§20)

- **法規檢討**：各機關應於本法施行後 2 年內，完成相關法規之制訂、修正或廢止 (§18)
- **過渡解釋**：法規修正完成前，由目的事業主管機關會商國科會解釋之 (§18)
- **政府內控**：政府使用 AI 執行業務，必須(1) 進行風險評估、(2) 訂定內控管理機制 (§19)
- **生效日期**：本法自公布之日起施行 (§20)

※ 使用生成式 AI 參考指引：考量行政院及所屬機關(構)利用生成式 AI 協助執行業務或提供服務，有助於行政效率之提升，且為保持執行公務之機密性及專業性，並促使各機關使用生成式 AI 有一致之認知及基本原則，行政院爰參考各國政府之審慎因應作法，研訂「行政院及所屬機關(構)使用生成式 AI 參考指引」，供各機關依循。各機關得視使用生成式 AI 之業務需求，參酌本參考指引另訂使用規範或內控管理措施。



第2單元-分組討論

1. 機關如何將資通安全維護計畫內容具體落實於日常營運中？哪些項目是實務上最容易推動的？哪些又是最困難的？如何提升維護計畫的實用性？
2. 機關如何精確地識別核心業務與核心資通系統？核心資通系統與非核心資通系統的分級，其防護要求有何不同？在資源有限的情況下，如何優先保護核心資通系統？
3. 機關如何利用情資分享提升整體資通安全防護能力？在實務上，進行情資分享可能有哪些限制或執行上的考量？如何鼓勵各單位更積極地參與情資分享？
4. 機關如何具體落實資通安全人員之獎懲規定？在實務上，如何有效激勵所屬人員提升資安意識與作為？如何平衡獎勵與懲處，以建立正向的資安文化？



第3單元

資通安全風險管理



第3單元學習目標

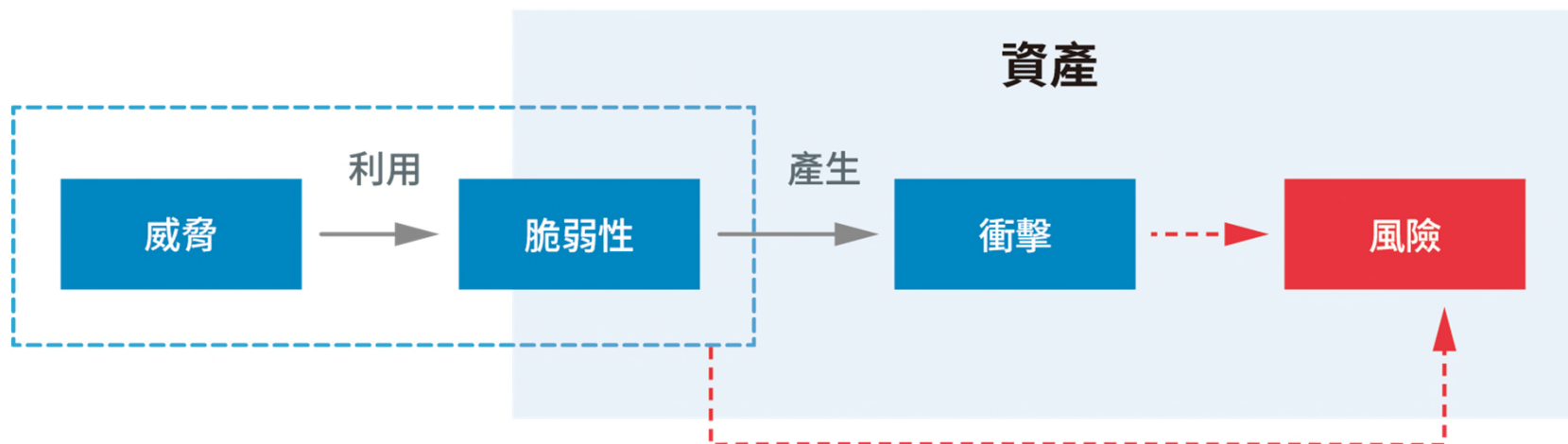
- ✓ 3-1 了解風險管理的流程
- ✓ 3-2 了解風險管理的全景建立
- ✓ 3-3 了解風險評鑑的作法
- ✓ 3-4 了解風險處理的作法
- ✓ 3-5 了解風險接受
- ✓ 3-6 國際相關防護及管理標準



3-1風險管理的流程(1/3)

■ 風險的定義及目標

- 「風險」是指「威脅」利用其相對應「脆弱性」造成組織或政府機關「資訊資產」受到「衝擊」的「可能性」



- 風險透過「衝擊」與其「可能性」兩個因素的結合來定義其影響程度或損害程度
- 風險管理的目標
 - 在最低的防護成本投入下獲得最優化的安全性(最優化非最強固，而是最合適)

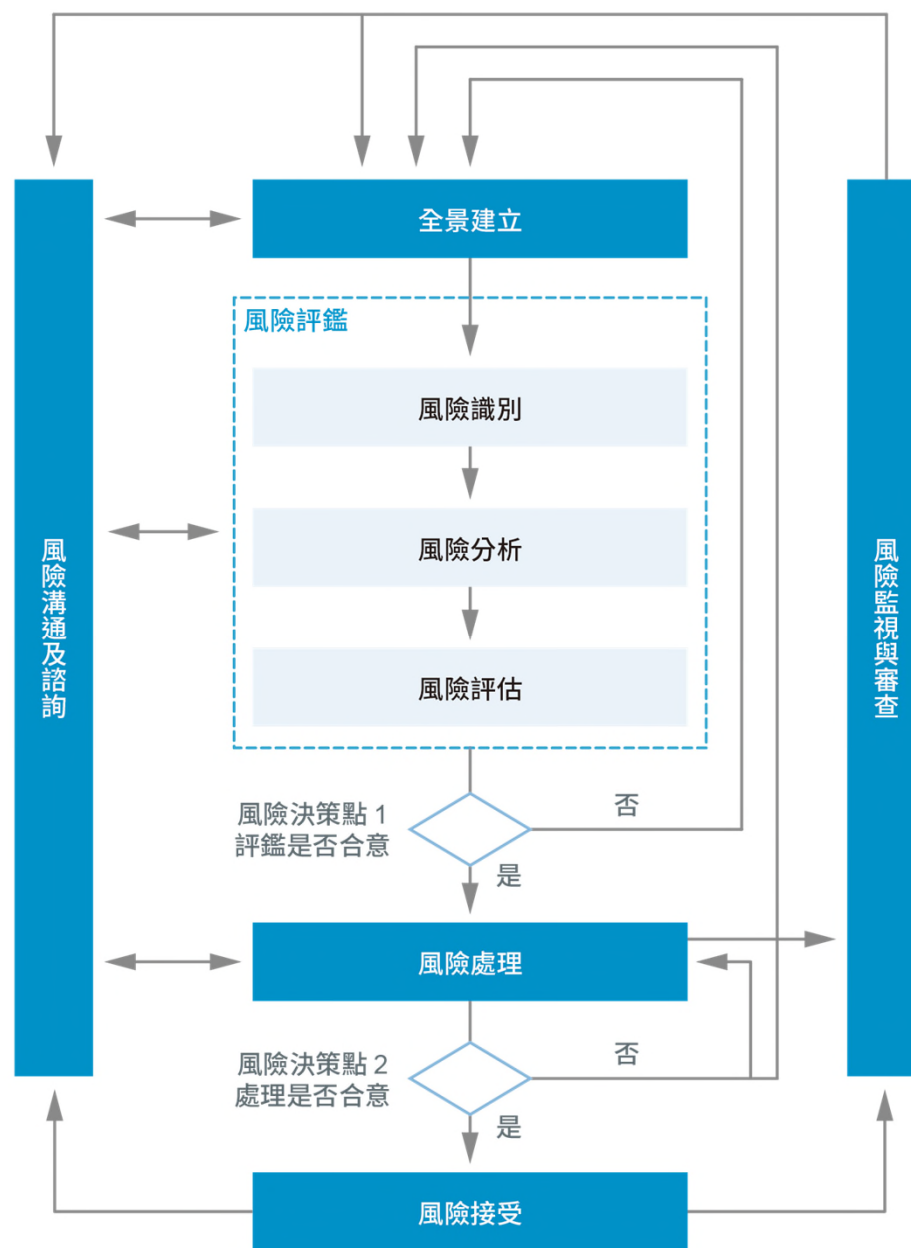


3-1風險管理的流程(2/3)

- **衝擊準則(Impact Criteria)**：主要訂定當威脅與弱點結合，破壞資訊及資通系統資產的機密性、完整性及可用性，對組織衝擊的嚴重性，可能包含營運受損、信譽損害、資安危害、業務與財務價值損失及違法情形等
- 建議將**衝擊嚴重性**，以機密性、完整性及可用性遭破壞的程度，分為普、中、高3等級，分別說明各等級對組織的影響，例如：
 - 機密性「普」級：資訊缺乏機密性保護，造成後果輕微或可忽視
 - 完整性「中」級：缺乏完整性保護，會造成組織嚴重後果，且災害會影響組織業務運作
 - 可用性「高」級：缺乏可用性保護，造成後果很嚴重，且災害會嚴重影響業務或信譽受損



3-1風險管理的流程(3/3)





3-2 風險管理的全景建立(1/2)

- 依相關法規進行資通安全風險評鑑，確定各項資訊作業安全需求水準，採行適當與充足的資安措施，確保資訊蒐集、處理、傳送、儲存及流通安全
- 機關資安政策中，明確聲明施政業務相關資通系統，應執行風險評鑑，並界定風險評鑑範圍、角色及責任等
- 進行風險評鑑與實作資安各項防護控制措施前，應
 - 識別機關內、外各方面的安全需求
 - 外部環境，包含但不限於
 - ◆ 衝擊組織目標的關鍵因素與趨勢
 - ◆ 社會與文化、政治、法律、法規命令、財務、科技、經濟及自然等，包含國際、國家、區域性或本地之競爭環境
 - 內部環境，包含但不限於
 - 機關治理、組織架構、角色及責任
 - 政策、目標及策略
 - 能力、資源及知識



3-2 風險管理的全景建立(2/2)

■ 進行風險評鑑與實作資安各項防護控制措施前，應：

➤ 規劃與定義風險管理基本準則

- － 風險管理作法
- － 風險評估準則
- － 衝擊準則
- － 風險接受準則

➤ 界定風險評鑑範圍，清查與盤點範圍內所有相關資通系統

- － 如果選用「詳細風險評鑑」作法，則需清查盤點資通系統的所有資訊及資通系統資產，同時整合這些資訊與資通系統資產，可能涉及的跨部門業務成員，共同組成資通系統風險評鑑組織，有助於執行與落實風險評鑑的成效



3-3 風險評鑑的作法(1/11)

- 可依據風險管理範圍與目標，採用不同作法，例如：高階風險評鑑作法或詳細風險評鑑作法
- 在每一循環中，作法可能不同，故在不同階段，選擇或發展適切風險管理作法

- 資通系統採高階風險評鑑：

- 依據「資通安全責任等級分級辦法」之資通系統防護需求分級原則，決定資通系統安全等級，以省時省力方式，進行高階風險分析。
- 可參考安全控制措施參考指引內容，選擇適用之安全控制措施，進行風險處理作業。

- 針對高等級資通系統，亦可再執行詳細風險評鑑：

- 資通系統經分級結果，屬高安全等級者，可在時間與資源允許情況下，或於資安事件發生後，進一步採行「詳細風險評鑑作法」，以尋求更適當風險處理方案。

- 資訊資產一般作法係採詳細風險評鑑，並尋求適當風險處理方案。



3-3 風險評鑑的作法(2/11)

■ 風險評鑑組織

- 建議成立「跨部門」風險評鑑組織
- 除資訊人員或資安人員外，應考量各部門業務相關資訊及資通系統資產風險與資產重要度
- 最熟悉者為各部門實際執行業務的承辦人員，因此「風險評鑑小組」成員，宜包含施政業務與支援該業務之資通系統相關人員(例如：資訊、資安、總務、人事、會計及業務人員)
- 應避免由單一成員，執行所有資通系統風險評鑑工作，而導致產出結果過於主觀，不符合該真實現況



3-3 風險評鑑的作法(3/11)

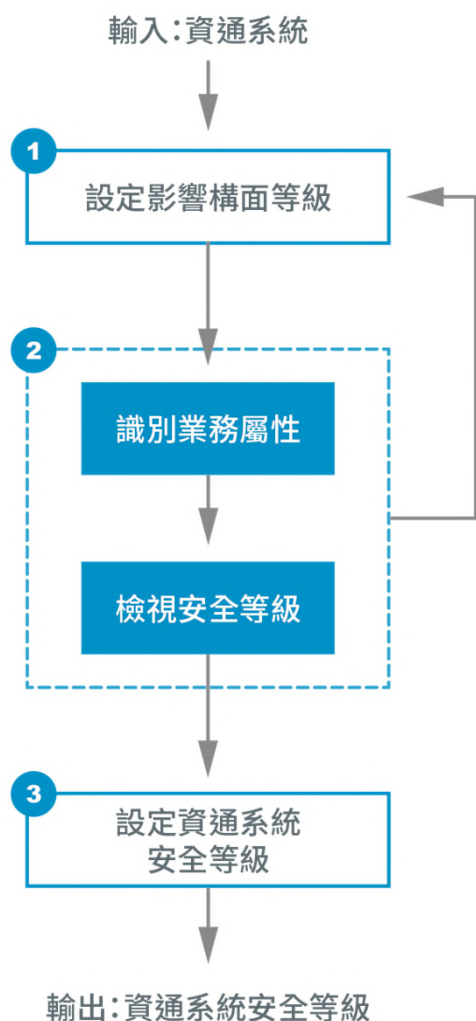
■ 高階風險評鑑作法

- 直接依資通系統分級方式，進行風險評鑑
- 使用時機
 - 實作風險管理的第1年、2年
- 優點
 - 一開始採用較簡單作法，容易獲得風險評鑑參與人員接受
 - 把握時效，讓最關鍵且需受保護的資通系統，優先被提出與實作
 - 可將資源與預算，運用於最有利之處
- 缺點
 - 評鑑結果較不精確，可能未識別某些營運過程或系統
 - 可視需要針對高安全等級之資產，進行詳細風險評鑑作業



3-3 風險評鑑的作法(4/11)

■ 高階風險評鑑作法



➤ 依資通安全責任等級分級辦法 執行資通系統分級處理程序

- 由業務承辦人依機密性、完整性、可用性及法律遵循性4大影響構面，分別考量資通系統於發生資安事件時，可能造成的衝擊，即衡量資通系統資料外洩、資料遭竄改、系統故障等情事時，可能造成後果嚴重程度，並據以評估、設定安全等級(安全等級分為普、中、高3級)
- 識別資通系統所支援之業務屬性，並由承辦單位主管檢視業務承辦人所設定安全等級之合理性
- 資通系統安全等級，經承辦單位主管與資訊主管確認後，最後由資通安全長核定



3-3 風險評鑑的作法(5/11)

■ 高階風險評鑑作法

- 影響構面「機密性」：資通系統發生資安事件時，可能造成系統資料外洩或遭竄改等情事，導致資料機密性受到損害。

安全等級	定義	說明
普	未經授權之資訊揭露，在機關營運、資產或信譽等方面，造成可預期「有限」負面影響	一般性資料：資料外洩不致影響機關權益，或僅導致機關權益輕微受損
中	未經授權的資訊揭露，在機關營運、資產或信譽等方面，造成可預期「嚴重」負面影響	敏感性資料：資料外洩將導致機關權益嚴重受損 涉及區域性或地區性個人資料
高	未經授權之資訊揭露，在機關營運、資產或信譽等方面，造成可預期「非常嚴重」或「災難性」負面影響	機密性資料：資料外洩將危及國家安全，導致機關權益非常嚴重受損 ■ 凡涉及國家安全之外交、情報、國境安全、財稅、經濟、金融、醫療等重要機敏系統 ■ 特殊屬性之個人資料(如：臥底警員、受保護證人、被害人等資料)，資料外洩可能會使相關個人身心受到危害、社會地位受到損害、或衍生財物損失等情形 ■ 涉及個人之醫療、基因、性生活、健康檢查、犯罪前科等資料，資料外洩將使個人權益非常嚴重受損。例如：醫療資訊系統、刑案資訊整合系統等 ■ 涉及全國性個人資料，包含出生年月日、國民身分證統一編號、護照號碼、特徵、指紋、婚姻、家庭、教育、職業、聯絡方式、財務情形、社會活動及其他得以直接或間接識別個人之資料。例如：戶役政資訊系統、護照管理系統等



3-3 風險評鑑的作法(6/11)

■ 高階風險評鑑作法

- 影響構面「完整性」：資通系統委外開發與營運時，若未有效執行資安防護作為，可能會造成系統完整性遭受破壞。

安全等級	定義	說明
普	未經授權之資訊修改或破壞，在機關營運、資產或信譽等方面，造成可預期「有限」負面影響	資料遭竄改不致影響機關權益，或僅導致機關權益輕微受損
中	未經授權之資訊修改或破壞，在機關營運、資產或信譽等方面，造成可預期「嚴重」負面影響	資料遭竄改將導致機關權益嚴重受損
高	未經授權之資訊修改或破壞，在機關、資產或信譽等方面，造成可預期「非常嚴重」或「災難性」負面影響	資料遭竄改將危及國家安全，導致機關權益非常嚴重受損



3-3 風險評鑑的作法(7/11)

■ 高階風險評鑑作法

- **影響構面「可用性」**：資通系統目的在輔助機關提升業務效能與服務品質，已成為機關業務運作不可或缺的一環，因此，系統故障(包含無法使用、異常運作等情形)可能導致業務執行效能降低，甚至業務中斷。

安全等級	定義	說明
普	資訊、資通系統之存取或使用上的中斷，在機關營運、資產或信譽等方面，造成可預期「有限」負面影響	■ 系統容許中斷時間較長(例如：72小時) ■ 系統故障對社會秩序、民生體系運作不致造成影響或僅有輕微影響 ■ 系統故障造成機關業務執行效能輕微降低
中	資訊、資通系統之存取或使用上的中斷，在機關營運、資產或信譽等方面，造成可預期「嚴重」負面影響	■ 系統容許中斷時間短 ■ 系統故障對社會秩序、民生體系運作將造成嚴重影響 ■ 系統故障造成機關業務執行效能嚴重降低
高	資訊、資通系統之存取或使用上的中斷，在機關營運、資產或信譽等方面，造成可預期「非常嚴重」或「災難性」負面影響	■ 系統容許中斷時間非常短(例如：30分鐘) ■ 系統故障對社會秩序、民生體系運作將造成非常嚴重影響，甚至危及國家安全 ■ 系統故障造成機關業務執行效能非常嚴重降低，甚至業務停頓



3-3 風險評鑑的作法(8/11)

■ 高階風險評鑑作法

- **影響構面「法律遵循性」**：危害程度評估，基於機關負有遵守法律規章責任與義務下，如發生違法情事時，機關將面臨衝擊，衝擊後果之嚴重程度，取決於法令規定

安全等級	定義	說明
普	未遵循其他資通相關法令或規範之情形	其他資通系統設置或運作於法令有相關規範之情形
中	未遵循其他資通相關法令或規範，使機關或其所屬人員受行政罰、懲戒或懲處	如未確實遵循資通系統設置或運作涉及之資通安全相關法令，可能使資通系統受影響而導致資通安全事件，或影響他人合法權益或機關執行業務之公正性及正當性，並使機關或其所屬人員受行政罰、懲戒或懲處
高	未遵循其他資通相關法令或規範，使機關或其所屬人員負刑事責任	如未確實遵循資通系統設置或運作涉及之資通安全相關法令，可能使資通系統受影響而導致資通安全事件，或影響他人合法權益或機關執行業務之公正性及正當性，並使機關所屬人員負刑事責任



3-3 風險評鑑的作法(9/11)

- 依「資通安全責任等級分級辦法」的安全等級評估方法，以「全球資訊網」為範例

➤ 全球資訊網：官方網站，提供機關簡介與介紹政策措施

影響構面		安全等級	原因說明
1. 機密性	初估	普	網站資訊皆為可公開的一般性資料
	異動		
2. 完整性	初估	普	主要提供資訊公告
	異動		
3. 可用性	初估	普	提供一般性資料瀏覽
	異動		
4. 法律遵循性	初估	普	必須符合智慧財產權相關法令，並遵守兒童及少年福利與權益保障法及相關規定，惟不涉及從根本上違反法律之可能性，也不致因違反規範導致嚴重不良後果
	異動		



3-3 風險評鑑的作法(10/11)

■ 詳細風險評鑑作法

- 對資產進行深度識別與鑑別作業，並對資產詳細列出可能面臨威脅與可能存在的弱點，做為評鑑風險與風險處理方法之依據
- 詳細步驟需考慮時間、耗費程度及專家意見
- 詳細風險評鑑作法，可以是定量方法、定性方法或二者結合。依據資產價值或需被保護的特性，評鑑威脅發生之可能性



3-3 風險評鑑的作法(11/11)

■ 詳細風險評鑑作法

- 藉由系統化方式，找出資通系統中，應該**優先處理**的資訊及資通系統資產與對應的風險，而施予適當的**防護控制措施**，以維持持續運作

風險識別

1. 資產識別
2. 威脅與脆弱性識別
3. 現有控制措施識別
4. 後果識別

風險分析

5. 後果評鑑(含資訊及資通系統資產價值評鑑)
6. 事件可能性評鑑
7. 決定風險等級

風險評估

8. 決定風險可接受等級



3-4 風險處理的作法(1/7)

- **風險接受準則**(Risk Acceptance Criteria)：先決定風險處理範圍
- 機關會因所負責任務的類別與性質、服務對象、內部資源及經費預算等因素，**影響風險處理範圍**，在有限資源下，決定哪些風險影響層面較大，需**優先進行處理**，哪些風險影響層面較小，在資源不足情況下，暫時予以**接受而保留風險**



3-4 風險處理的作法(2/7)

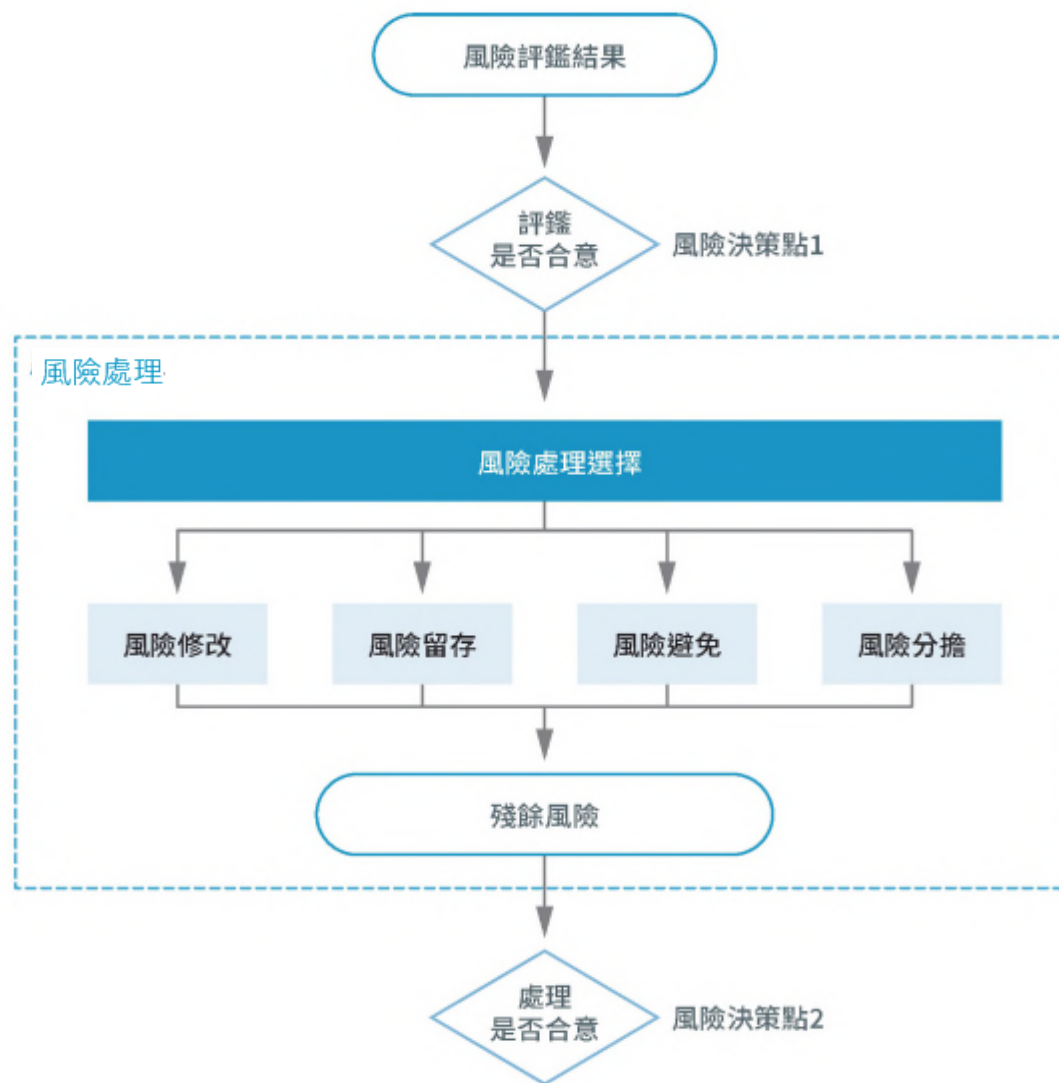
- **風險接受準則**，因機關負責任務不同而考量重點不同
- 可能影響**風險接受準則**項目
 - 業務需求與目標
 - 法律、法令、規章及合約方面要求
 - 資源分配狀況
 - 技術成熟度
 - 經費預算
 - 社會與人道主義因素



3-4 風險處理的作法(3/7)

■ 風險處理階段

- 風險處理活動，應依據風險評鑑結果、實作風險處理方案之預期成本及預期利益等，選擇適當行動方案
- 一般而言，宜使風險不利後果合理的降低





3-4 風險處理的作法(4/7)

■ 風險修改

- 藉由施行、移除或改變安全控制措施，修訂或降低風險等級，使殘餘風險被重新評定為可接受
- 控制措施可提供多種形式保護，包含：矯正、消弭、預防、衝擊最小化、制止、偵測、復原、監視及認知，於控制措施選擇期間，應權衡控制措施實作及維護之成本，與受保護的資產價值加以比較
- 以上風險評鑑採用「高階風險評鑑」作法者，其控制措施選擇，可以參考「安全控制措施參考指引」的防護基準，依據風險評鑑等級，區分為普中高3級，選擇適用的安全控制措施



3-4 風險處理的作法(5/7)

■ 風險留存

- 依據風險評估結果，確認無進一步行動，而保留風險決策。
- 若風險等級符合風險接受準則，則不需要實作額外控制措施，風險將被保留，但需基於正式決策過程。
 - 例如：自建機房容易斷電，但沒有空間可以建置發電機，也沒辦法保險，亦不行搬至其他辦公場所，只好保留此風險
- 風險保留後，仍為殘餘風險，必須定期監控與考量實施業務持續管理計畫，以利風險發生時，快速因應處理。



3-4 風險處理的作法(6/7)

■ 風險避免

- 避免可能造成特定風險增加的活動或情況。

範例1

管制使用任何第三方未經嚴格安全審核的開源函式庫



範例2

發電機放置地下室



颱風淹水



將發電機移置樓上

- 辦理社交工程演練，除了需進行演練作業外，強化認知訓練與宣導，才是防範社交工程攻擊或進階持續性威脅攻擊最經濟有效的控制措施。



3-4 風險處理的作法(7/7)



■ 風險分擔

- 依據風險評估結果，將部分風險分擔至能有效管理特定風險的另一方。
- 採用方式
 - 保險(用在硬體資產上較容易)。
 - 於合約中增訂懲罰性違約金條款。



3-5 風險接受



- 風險處理計畫宜描述將如何處理評定之風險，以滿足**風險接受準則**。
- 於某些情況中，殘餘風險之等級可能不符合風險接受準則，因為該準則於適用時未考量當時之環境。
- 可能可主張因為伴隨風險之利益非常有吸引力，或是因為風險修改之成本太高，而必須接受風險。此種環境指出風險接受準則不恰當，若可能宜加以修訂。
- 決策者可能必須接受不符合常態風險接受準則之風險 (normal risk acceptance criteria)。若此為必要，決策者宜明確地在該風險上註解，並包含無視常態風險接受準則之決策的衡量理由。



3-6 國際相關防護及管理標準(1/5)

■ 資通安全框架

➤ NIST CSF 2.0 : 2024

1. 資通安全框架(CSF) 概述
 2. CSF 核心介紹
 3. CSF 概況及層級介紹
 - 3.1. CSF 剖繪
 - 3.2. CSF 層級
 4. 補充 CSF的線上資源介紹
 5. 加強網路安全風險溝通與整合
 - 5.1. 改善風險管理溝通
 - 5.2. 改善與其他風險管理計畫的 回應整合
- 附錄A：CSF 核心
附錄 B：CSF 層級
附錄 C：詞彙表



<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>



3-6 國際相關防護及管理標準(2/5)

■ 資通安全防護框架

➤ NIST CSF 2.0 : 2024

- NIST 網路安全框架 (Cybersecurity Framework, CSF)：是一個自願性的框架，旨在幫助組織更好地管理及降低網路安全風險。最初的版本 CSF 1.0 發布於 2014 年，主要關注保護。經過多年的實踐及回饋，NIST 在 2024 年發布了 CSF 2.0，進行了重要的更新及擴展。
- CSF 2.0 的六大功能：
 - 治理 (Govern - GV)：建立並溝通網路安全策略、角色、責任及監督。
 - 識別 (Identify - ID)：了解組織的網路安全風險，包括資產、業務環境、治理結構、風險評估及供應鏈。
 - 保護 (Protect - PR)：制定並實施保障措施，以支持限制或遏制網路安全事件的能力。
 - 偵測 (Detect - DE)：制定並實施活動，以識別網路安全事件的發生。
 - 回應 (Respond - RS)：制定並實施有關網路安全事件的行動。
 - 復原 (Recover - RC)：制定並實施計劃，以便在網路安全事件後恢復能力及服務。



3-6 國際相關防護及管理標準(3/5)

■ 管理資訊安全風險之指引 ➤ CNS 27005 : 2024

Information security, cybersecurity and privacy protection
- Guidance on managing information security risks

1. 適用範圍
2. 引用標準
3. 用語及定義
4. 本標準之結構
5. 資訊安全風險管理
6. 全景建立
7. 資訊安全風險評鑑過程
8. 資訊安全風險處理過程
9. 運作
10. 善用相關之ISMS 過程

附錄A(參考) 支援風險評鑑過程之技術示例



3-6 國際相關防護及管理標準(4/5)

■ 管理資訊安全風險之指引 ➤ CNS 27005 : 2024

➤ CNS 27005:2024

提供組織建立、實施、維護及持續改進資訊安全風險管理流程的指導方針。其核心目標是幫助組織有效地識別、分析、評估及處理資訊安全風險，以保護其資訊資產。

➤ 主要重點：

- － 風險管理框架：強調建立一個結構化的風險管理框架，該框架應融入組織的整體資訊安全管理系統 (ISMS)。
- － 背景理解：強調在進行風險評估之前，需要充分理解組織的內外部環境、利害關係者的需求及期望，以及確定風險管理的範圍。



3-6 國際相關防護及管理標準(5/5)

■ 管理資訊安全風險之指引 ➤ CNS 27005 : 2024

- **風險評鑑過程**：詳細說明風險評鑑的步驟
 - **風險識別 (Risk Identification)**: 識別可能影響資訊安全的威脅及脆弱性。
 - **風險分析 (Risk Analysis)**: 評估威脅發生的可能性及一旦發生所造成的影響。
 - **風險評估 (Risk Evaluation)**: 將風險分析的結果與風險接受準則進行比較。
- **風險處理**：提供了多種風險處理選項，例如風險規避、風險轉移、風險減輕及風險接受，並指導組織如何選擇及實施適當的處理方案。
- **風險接受**：強調在了解風險的情況下，做出接受決策的過程。
- **風險溝通與諮詢**：說明與相關利害關係人就風險及其處理方式進行溝通及諮詢的重要性。
- **監控與審查**：強調定期監控及審查資訊安全風險管理過程的必要性，以確保其持續有效。



第3單元-分組討論

1. 機關如何依據機密性、完整性、可用性及法律遵循性四個構面，評估不同資安事件對組織造成「高」、「中」、「普」嚴重程度？在實務上評估衝擊嚴重性時，常見的經驗與挑戰為何？
2. 機關在何種情況下，會選擇採用高階或詳細的風險評鑑方法？當時間與資源有限時，如何判斷是否需要進行更詳細的評鑑？
3. 機關在設定風險接受準則時，主要會考量哪些因素？在什麼情況下，機關可能會接受一個不完全符合常態風險接受準則的風險？正式接受風險後，還需要進行哪些後續作業？
4. 機關是否有參考其他國際標準或規範來建立或改進資安風險管理流程？這些標準中，哪些概念（如 NIST CSF 的六大功能或 CNS 27005 的風險評估流程）對您的實務工作最具啟發性或幫助？在實務應用這些標準時，可能會遇到哪些挑戰？



第4單元

資通安全管理面暨 認知與訓練應辦事項



第4單元學習目標

- 4-1 了解資通系統分級與防護基準
- 4-2 了解資訊安全管理系統
- 4-3 了解資通安全專職人員
- 4-4 了解內部資通安全稽核
- 4-5 了解營運持續計畫演練
- 4-6 了解資安治理成熟度
- 4-7 了解資安認知與訓練



4-1 資通系統分級與防護基準(1/3)

■ 資通安全管理面應辦事項 ➤ 資通系統分級與防護基準規定

資通安全責任等級		應辦事項
公務機關	特定非公務機關	
A級、B級、C級		針對自行或委外開發之資通系統，依附表九完成資通系統分級，並完成附表十之控制措施；其後應每年至少檢視1次資通系統分級及其防護基準之妥適性。
D 級 、 E 級		無要求

- 資通系統之性質為共用性系統者，由該資通系統之主責設置、維護或開發機關判斷是否屬於核心資通系統
- 應辦事項辦理期限：**資通系統分級及防護基準應於初次受核定或等級變更後之1年內完成；資通系統新增、系統分級變更或其適用防護基準有異動情形時，亦同。**屬C 級之特定非公務機關**應於初次受核定或等級變更後之1年內依附表九完成分級，並 於2年內完成附表十控制措施



4-1 資通系統分級與防護基準(2/3)

■ 資通安全管理面應辦事項

附表9 資通系統防護需求分級原則

防護需求 等級 構面	高	中	普
機密性(C)	發生資通安全事件致資通系統受影響時，可能造成未經授權之資訊揭露，對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	發生資通安全事件致資通系統受影響時，可能造成未經授權之資訊揭露，對機關之營運、資產或信譽等方面將產生嚴重之影響。	發生資通安全事件致資通系統受影響時，可能造成未經授權之資訊揭露，對機關之營運、資產或信譽等方面將產生有限之影響。
完整性(I)	發生資通安全事件致資通系統受影響時，可能造成資訊錯誤或遭竄改等情事，對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	發生資通安全事件致資通系統受影響時，可能造成資訊錯誤或遭竄改等情事，對機關之營運、資產或信譽等方面將產生嚴重之影響。	發生資通安全事件致資通系統受影響時，可能造成資訊錯誤或遭竄改等情事，對機關之營運、資產或信譽等方面將產生有限之影響。
可用性(A)	發生資通安全事件致資通系統受影響時，可能造成對資訊、資通系統之存取或使用之中斷對機關之營運、資產或信譽等方面將產生非常嚴重或災難性之影響。	發生資通安全事件致資通系統受影響時，可能造成對資訊、資通系統之存取或使用之中斷對機關之營運、資產或信譽等方面將產生嚴重之影響。	發生資通安全事件致資通系統受影響時，可能造成對資訊、資通系統之存取或使用之中斷對機關之營運、資產或信譽等方面將產生有限之影響。
法律遵循性(L)	如未確實遵循資通系統設置或運作涉及之資通安全相關法令可能使資通系統受影響而導致資通安全事件，或影響他人合法權益或機關執行業務之公正性及正當性，並使機關所屬人員負刑事責任。	如未確實遵循資通系統設置或運作涉及之資通安全相關法令可能使資通系統受影響而導致資通安全事件，或影響他人合法權益或機關執行業務之公正性及正當性，並使機關或其所屬人員受行政罰、懲戒或懲處	其他資通系統設置或運作於法令有相關規範之情形。



4-1 資通系統分級與防護基準(3/3)

■ 資通安全管理面應辦事項

附表10資通系統防護基準

構面	控制措施
1. 存取控制(3)	帳號管理、最小權限、遠端存取
2. 事件日誌與可歸責性(6)	記錄事件、日誌紀錄內容、日誌儲存容量、日誌處理失效之回應、時戳及校時、日誌資訊之保護
3. 營運持續計畫(2)	資料備份、系統備援
4. 識別與鑑別(3)	內部使用者之識別與鑑別、身分驗證管理、鑑別資訊保護
5. 系統與服務獲得(8)	系統發展生命週期之需求階段、設計階段、開發階段、測試階段、部署與維運階段、委外階段、獲得程序、系統文件
6. 系統與通訊保護(2)	傳輸之機密性與完整性、資料儲存之安全
7. 系統與資訊完整性(3)	漏洞修復、資通系統監控、軟體及資訊完整性

170項
控制措施

高

共計75項
控制措施

中

共計55項
控制措施

低

共計40項
控制措施



4-2 資訊安全管理系統(1/5)

■ 資通安全管理面應辦事項

➤ ISMS之導入及通過公正第三方之驗證規定

資通安全 責任等級		ISMS導入要求	ISMS驗證要求
公務 機關	特定 非公務機關		
A級、B級		全部核心資通系統導入 CNS27001 或 ISO 27001 等資訊安全管理系統標準、其他具有同等或以上效果之系統或標準，或其他公務機關自行發展並經主管機關認可之標準。	完成公正第三方驗證，並持續維持其驗證有效性。
C級			未要求
D 級 、 E 級		未要求	未要求

- 「公正第三方驗證」所稱第三方，指通過我國標準法主管機關委託機構認證之機構；第三方核發之驗證證書應有前開委託機構之認證標誌

- 應辦事項辦理期限：

A級級B級機關：資訊安全管理系統之導入及通過公正第三方之驗證，應於初次受核定或等級變更後之2年內，全部核心資通系統導入資訊安全管理系統，並於3年內完成公正第三方驗證。

C級機關：應於初次受核定或等級變更後之2年內，全部核心資通系統導入資訊安全管理系統。



4-2 資訊安全管理系統(2/5)

分類	ISO/IEC	年份	標準名稱
詞彙標準	27000	2018	資訊安全管理系統-概觀及詞彙
要求事項標準	27001	2022	資訊安全管理系統-要求
	27006-1	2024	提供資訊安全管理系統審核與驗證機構的要求-第1部分:一般要求
	27006-2	2021	提供資訊安全管理系統審核與認證機構的要求-第2部分:隱私資訊管理系統
指導綱要標準	27002	2022	資訊安全控制措施
	27003	2017	資訊安全管理系統 – 指導綱要
	27004	2016	資訊安全管理- 監控、測量、分析與評估
	27005	2022	資訊安全風險管理指引
	27007	2020	資訊安全管理系統稽核指導綱要
	27008	2019	資訊安全控制評鑑指導綱要
	27013	2021	ISO/IEC 27001 與 ISO/IEC 20000-1 整合實作指引
	27014	2020	資訊安全治理
行業特定指導綱要標準	27010	2015	跨行業與跨組織通訊的資訊安全管理
	27011	2024	基於 ISO/IEC 27002 的電信組織資訊安全控制措施
	27017	2015	基於 ISO/IEC 27002 的雲端服務資訊安全控制措施 指導綱要
	27018	2019	作為個人可識別資訊(PII)處理者的公有雲保護個人可識別資訊指導綱要
	27701	2025	隱私資訊管理系統要求事項及指導綱要



4-2 資訊安全管理系統(3/5)

■ CNS 27001 : 2023 資訊安全管理系統 - 要求事項

1. 適用範圍
2. 引用標準
3. 用語及定義
4. 組織全景
5. 領導作為
6. 規劃
7. 支援
8. 運作
9. 績效評估
10. 改善

附錄 A (規定)

參考控制目標及控制措施

A.5 組織控制措施 (37)

A.6 人員控制措施 (8)

A.7 實體控制措施 (14)

A.8 技術控制措施 (34)

4個主類別，共計93項

■ CNS 27002 : 2023 資訊安全控制措施

附錄A(參考)使用屬性

附錄B(參考)CNS 27002 : 2023(本標準)與CNS 27002 : 2015之對應



4-2 資訊安全管理系統(4/5)

■ CNS 27002 : 2023 資訊安全控制措施

章次及章名	CNS 27002 : 2023 節次及節名			頁次
1. 適用範圍				8
2. 引用標準				8
3. 用語、定義及縮寫	3.1 用語及定義 3.2 縮寫			8-13
4. 本標準之結構	4.1 節次 4.2 主題及屬性 4.3 控制措施布局			13-15
5. 組織控制措施	5.1 資訊安全政策 5.2 資訊安全之角色及責任 5.3 職務區隔 5.4 管理階層責任 5.5 與權責機關之聯繫 5.6 與特殊關注群組之聯繫 5.7 威脅情資 5.8 專案管理之資訊安全 5.9 資訊及其他相關聯資產之清冊 5.10 可接受使用資訊及其他相關聯資產 5.11 資產之歸還 5.12 資訊之分類分級 5.13 資訊之標示	5.14 資訊傳送 5.15 存取控制 5.16 身分管理 5.17 鑑別資訊 5.18 存取權限 5.19 供應者關係中之資訊安全 5.20 於供應者協議中闡明資訊安全 5.21 管理ICT供應鏈中之資訊安全 5.22 供應者服務之監視、審查及變更管理 5.23 使用雲端服務之資訊安全 5.24 資訊安全事故管理規劃及準備 5.25 資訊之評鑑及決策 5.26 對資訊安全事故之回應	5.27 由資訊安全事故中學習 5.28 證據之蒐集 5.29 中斷期間之資訊安全 5.30 營運持續之ICT備妥性 5.31 法律、法令、法規及契約要求事項 5.32 智慧財產權 5.33 紀錄之保護 5.34 隱私及PII保護 5.35 資訊安全之獨立審查 5.36 資訊安全政策、規則及標準之遵循性 5.37 書面記錄之運作程序	15-60
6. 人員控制措施	6.1 篩選 6.2 聘用條款及條件 6.3 資訊安全認知及教育訓練 6.4 獎懲過程	6.5 聘用終止或變更後之責任 6.6 機密性或保密協議 6.7 遠端工作 6.8 資訊安全事件通報		60-68



4-2 資訊安全管理系統(5/5)

■ CNS 27002 : 2023 資訊安全控制措施

章次及章名	CNS 27002 : 2023 節次及節名			頁次
7. 實體控制措施	7.1 實體安全周界 7.2 實體進入 7.3 保全辦公室、房間及設施 7.4 實體安全監視 7.5 防範實體及環境威脅	7.6 於安全區域內工作 7.7 桌面淨空及螢幕淨空 7.8 設備安置及保護 7.9 場所外資產之安全 7.10 儲存媒體	7.11 支援之公用服務事業 7.12 佈纜安全 7.13 設備維護 7.14 設備汰除或重新使用之保全	68-81
8. 技術控制措施	8.1 使用者端點裝置 8.2 特殊存取權限 8.3 資訊存取限制 8.4 對原始碼之存取 8.5 安全鑑別 8.6 容量管理 8.7 防範惡意軟體 8.8 技術脆弱性管理 8.9 組態管理 8.10 資訊刪除 8.11 資料遮蔽 8.12 資料洩露預防	8.13 資訊備份 8.14 資訊處理設施之多備 8.15 存錄 8.16 監視活動 8.17 鐘訊同步 8.18 具特殊權限公用程式之使用 8.19 運作中系統之軟體安裝 8.20 網路安全 8.21 網路服務之安全 8.22 網路區隔 8.23 網頁過濾 8.24 密碼技術之使用	8.25 安全開發生命週期 8.26 應用系統安全要求事項 8.27 安全系統架構及工程原則 8.28 安全程式設計 8.29 開發及驗收中之安全測試 8.30 委外開發 8.31 開發、測試與運作環境之區隔 8.32 變更管理 8.33 測試資訊 8.34 稽核測試期間資訊系統之保護	81-129
附錄A (參考)	使用屬性			130-140
附錄B (參考)	CNS 27002 : 2023 (本標準) 與 CNS 27002 : 2015 之對應			140-147
參考資料				147-150
名詞對照				150-160



4-3 資通安全專職人員

■ 資通安全管理面應辦事項 ➤ 資通安全專職人員規定

資通安全責任等級		資通安全專職人員之配置人數	
公務 機關	特定 非公務機關	公務 機關	特定 非公務機關
A級		配置4人以上	
B級		配置2人以上	
C級		配置1人以上	
D 級 、 E 級		無要求	

備註：

資通安全專職人員：指應全職執行資通安全業務者，亦即資通安全為其主要核心業務，且應優先辦理。資通安全專職人員以外之資訊人員，指其他實際從事資通安全業務或資訊業務之人員。

應辦事項辦理期限：配置資通安全專職人員應於初次受核定或等級變更後之1年內完成；人員異動時，亦同。



4-4 內部資通安全稽核(1/2)

■ 資通安全管理面應辦事項

➤ 內部資通安全稽核規定

資通安全責任等級		辦理內部稽核次數
公務機關	特定非公務機關	
A級		每年辦理2次
B級		每年辦理1次
C級		每2年辦理1次
D 級 、 E 級		無要求

- 應辦事項辦理期限：應於初次受核定、等級變更或核心資通系統異動後之次年度起，依附表規定辦理



4-4 內部資通安全稽核(2/2)

■ 稽核類別

第一方稽核	第二方稽核	第三方稽核
內部資通安全稽核	上級機關稽核下級機關，或 機關稽核委外廠商	導入及通過公正 第三方ISMS驗證
資通安全責任等級分級 辦法(§11)應辦事項：內 部資通安全稽核。	1.資通安全管理法： §6：主管機關應定期公布對公務機關資通安全 維護計畫實施情形稽核概況報告 §8：主管機關得定期或不定期稽核公務機關及 特定非公務機關之資通安全維護計畫實施情形 §15：公務機關應稽核其所屬、所監督之機關資 通安全維護計畫實施情形 §20：中央目的事業主管機關應稽核關鍵基礎設 施提供者 §21：中央目的事業主管機關得稽核特定非公務 機關之資通安全維護計畫實施情形 2.資通安全管理法施行細則(§7)：委託機關以稽 核或其他適當方式確認受託業務之執行情形	CNS 27001：2023 9.2.2 內部稽核計畫： 組織應規劃、建立、實 作及維持稽核計畫。
1. 稽核範圍：全機關 2. 稽核項目： 稽核項目檢核表 資訊安全控制措施	1. 稽核範圍：全機關 2. 稽核項目： 稽核項目檢核表	1. 稽核範圍：驗證範圍 2. 稽核項目： 資訊安全控制措施



4-5 營運持續計畫演練(1/11)

■ 資通安全管理面應辦事項 ➤ 營運持續計畫演練規定

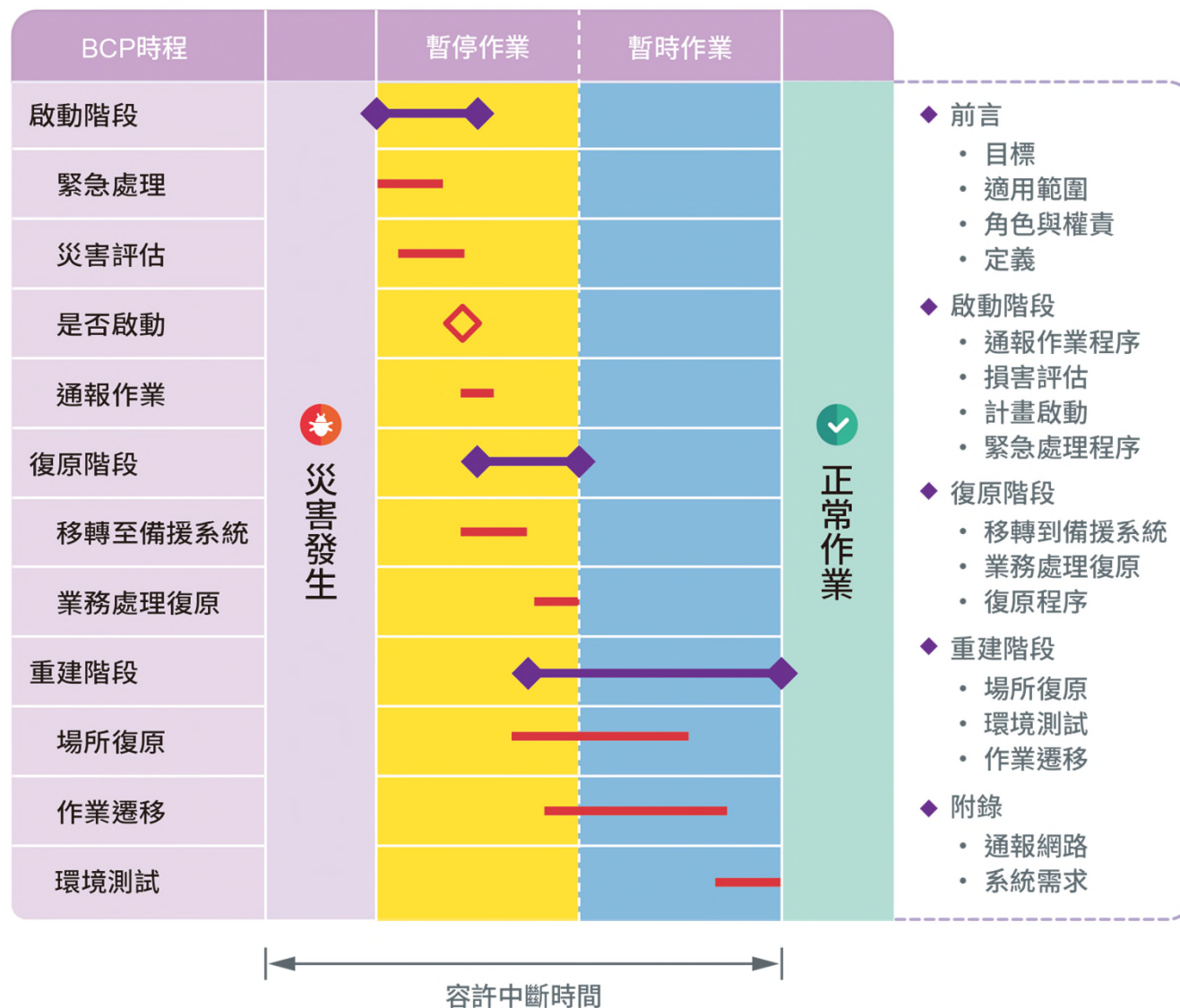
資通安全責任等級		辦理演練次數
公務機關	特定非公務機關	
A級		全部核心資通系統 每年辦理1次。
B級、C級		全部核心資通系統 每2年辦理1次。
D 級、E 級		無要求

- 營運持續計畫演練與資通系統防護基準之營運持續計畫息息相關，於第5單元資通系統防護控制措施進一步說明
- 應辦事項應於初次受核定、等級變更或核心資通系統異動後之次年度起，依附表規定辦理。



4-5 營運持續計畫演練(2/11)

■ 營運持續計畫時程：





4-5 營運持續計畫演練(3/11)



■ 資通安全維護計畫範本：(核心業務重點說明)

核心資通系統	重要性說明	最大可容忍中斷時間
• 依資通安全責任等級分級辦法規定為支持核心業務運作必要之系統 • 依資通安全責任等級分級辦法附表九資通系統防護需求分級原則之規定，判定其防護需求等級為高亦應列為核心資通系統	• 依數位發展部資通安全署提供的維護計畫範本內容，重要性說明係指說明該業務對機關之重要性 • 例如對機關財務及信譽上影響，對民眾影響，對社會經濟影響，對其他機關業務運作影響，法律遵循性影響或其他重要性之說明	• 指在無法提供核心服務或未執行核心服務需要的作業或系統時，可能產生的不利衝擊變得無法接受所需的時間 • 可能是法令法規的要求、合約的要求，或利害相關方(如主管機關)的要求。



4-5 營運持續計畫演練(4/11)

■ 營運持續之必要性

- 為使組織不會因突發事件造成業務運作中斷，需要有專責人員去識別來自組織外部，包含全球大環境的風險與威脅
- 因應資通安全管理法實施，機關需要透過資通安全責任等級分級辦法核定的資安等級，識別出營運持續需求
- 要成功將營運持續機制扣合施政目標，並納入組織日常運作，需要機關高層人員支援與調用資源，並與營運持續專責人員共同協作



4-5 營運持續計畫演練(5/11)

■ 營運持續管理系統 – ISO 22301 : 2019

- **標準名稱：** 安全與韌性-營運持續管理系統-要求事項 (Security and Resilience-Business Continuity Management Systems-Requirements)
- **目的：** 規範實施與維護營運持續管理系統 (BCMS) 的結構與要求事項
- **適用範圍：** 本文件規定了實施、維護及改善營運持續管理系統的要求事項，以防止、減少發生營運中斷的可能性、準備、應變及恢復
- **實作指引：** 營運持續管理系統指引 – ISO 22313 : 2020 (Societal security — Business continuity management systems - Guidelines for processes of business continuity management)



4-5 營運持續計畫演練(6/11)

■ 名詞釋義：ISO 22301：2019

- **營運持續(Business Continuity, BC)**
 - 組織在營運持續中斷期間，以預定容量在可接受的時間範圍內，繼續交付產品與服務的能力
- **營運持續管理(Business Continuity Management, BCM)**
 - 實施與維護營運持續的過程
- **營運持續管理系統(Business Continuity Management System, BCMS)**
 - 建立、實施、維運、監控、審查、維護及改善營運持續的整體管理系統的一部分 (ISO 22300：2021)
- **營運持續計畫(Business Continuity Plan, BCP)**
 - 指導組織因應營運運作中斷、反應重啟及恢復營運持續目標之文件化資訊
- **營運衝擊分析(Business Impact Analysis, BIA)**
 - 分析營運運作中斷隨時間推移對組織的衝擊的過程



4-5 營運持續計畫演練(7/11)

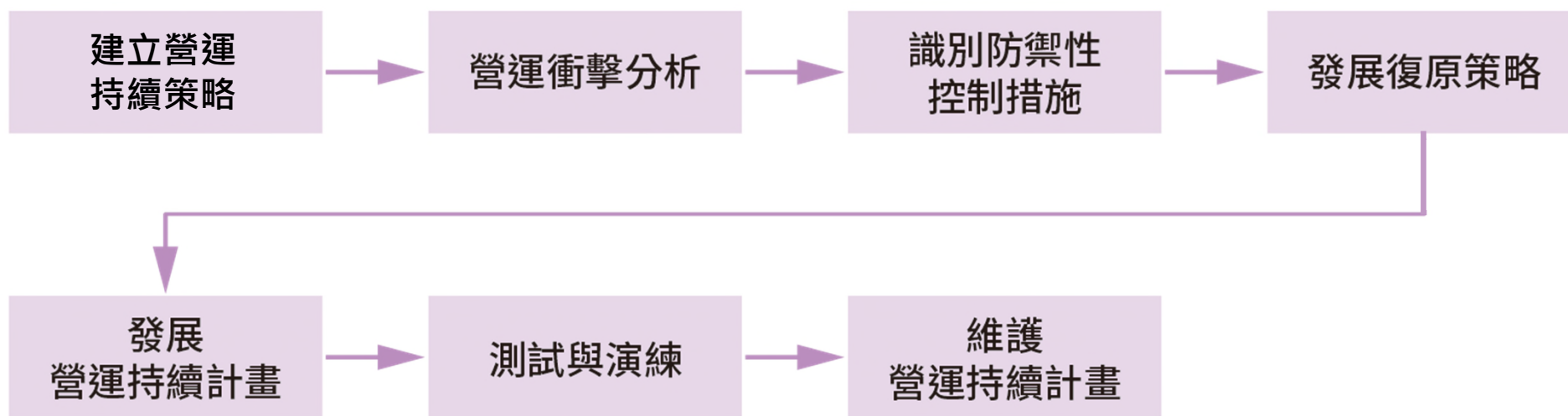
■ 名詞釋義：ISO 22301：2019

- 最大可容忍中斷時間(Maximum Tolerable Period of Disruption, MTPD)
 - 組織於發生營運中斷而無法提供產品或服務時，可承受最長的空窗期間
- 復原點目標(Recovery Point Objective, RPO)
 - 組織於發生營運中斷事件後，資料復原可以用來啟動營運持續達成最低營運持續目標的資料時間點(係組織能容忍的最大資料丟失量)
- 復原時間目標(Recovery Time Objective, RTO)
 - 組織於發生營運中斷事件後，系統復原可以用來啟動營運持續達成最低營運持續目標的系統時間點



4-5 營運持續計畫演練(8/11)

■ 營運持續-管理程序



- 必須獲得高階管理人員「認同與支持」
- 必須是核心業務所有相關部門投入，並非是資訊部門的責任



4-5 營運持續計畫演練(9/11)

■ 營運持續-營運衝擊分析

- 營運衝擊分析(Business Impact Analysis)，簡稱BIA
- 用來了解當災害發生後的嚴重程度，以及需要多少時間來處理
- BIA的步驟：
 - 識別機關的核心業務功能
 - 識別核心業務所仰賴的資源
 - 計算核心業務可容許缺少資源的時間
 - 識別核心業務面臨的威脅與弱點
 - 計算不同業務功能的風險
 - 確認業務功能與資源復原的先後順序



4-5 營運持續計畫演練(10/11)

■ 演練目的

- 檢驗BCP的可行性並補強未考量之缺陷
- 確保在可容許中斷時間內可完成復原作業
- 使相關人員熟悉相關災害復原的作業

■ 演練實務(1/2)

- 對全部核心資通系統訂定營運持續計畫，定期辦理營運持續演練：
 - A級機關每年至少演練過1次。
 - B級、C級機關每2年至少演練過1次。

演練情境要求

1. 演練情境是否納入業務單位角色，演練結果與持續營運目標之符合性，亦應經業務單位確認，以確保營運持續演練之有效性，並應提報資安長。
2. 是否依演練結果滾動調整相關程序及營運持續計畫、並提報資安長。
3. 建議評估是否需納入複合式演練情境。



4-5 營運持續計畫演練(11/11)

■ 演練實務(2/2)

- 是否至少針對核心業務訂定最大可容忍中斷時間(MTPD)，並至少針對防護需求為中等級以上之資通系統，訂定從中斷後至重新恢復服務之可容忍時間要求(RTO)，及可容忍資料損失之時間要求(RPO)？是否依RPO訂定資料及系統之備份頻率？

演練時間要求

1. 核心資通系統之RTO亦不宜大於非核心資通系統之RTO。
2. $MTPD(\text{最大可容忍中斷時間}) = RTO + WRT$
 - 了解機關RTO定義是否包含 WRT(工作恢復時間)，
 - 確認設定之合理性，RTO不可大於MTPD。
 - 確認備份週期不可大於RPO



4-6 資安治理成熟度評估(1/9)

■ 資通安全管理面應辦事項 ➤ 資安治理成熟度評估規定

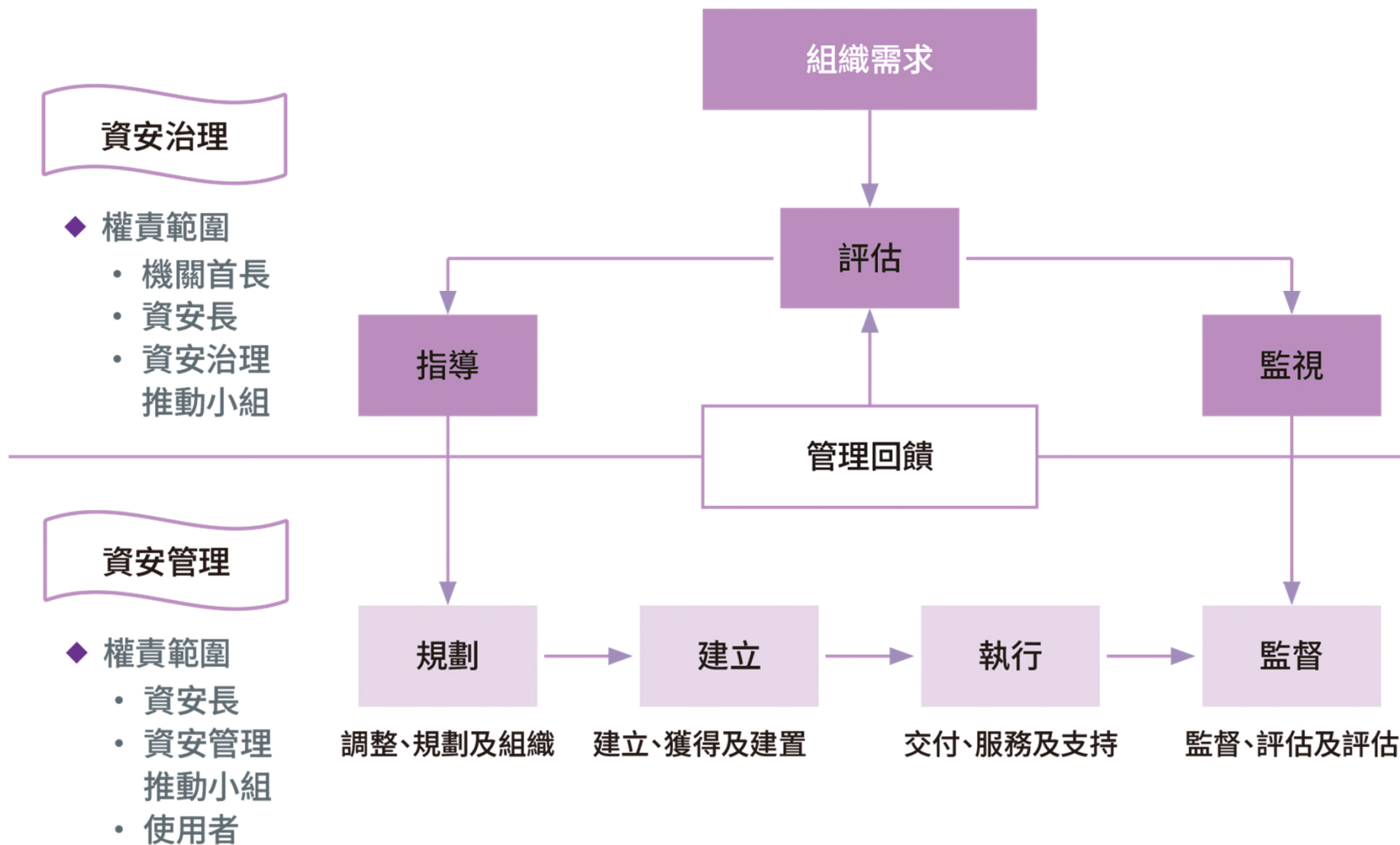
資通安全責任等級	辦理 資安治理成熟度評估 次數
公務機關及關鍵基礎設施提供者	
A級	每年應辦理1次
B級	
C級、D 級 、 E 級	無要求

- **應辦事項：**應於初次受核定、等級變更或核心資通系統異動後之次年度起，依附表規定辦理



4-6 資安治理成熟度評估(2/9)

■ 資安治理與資安管理

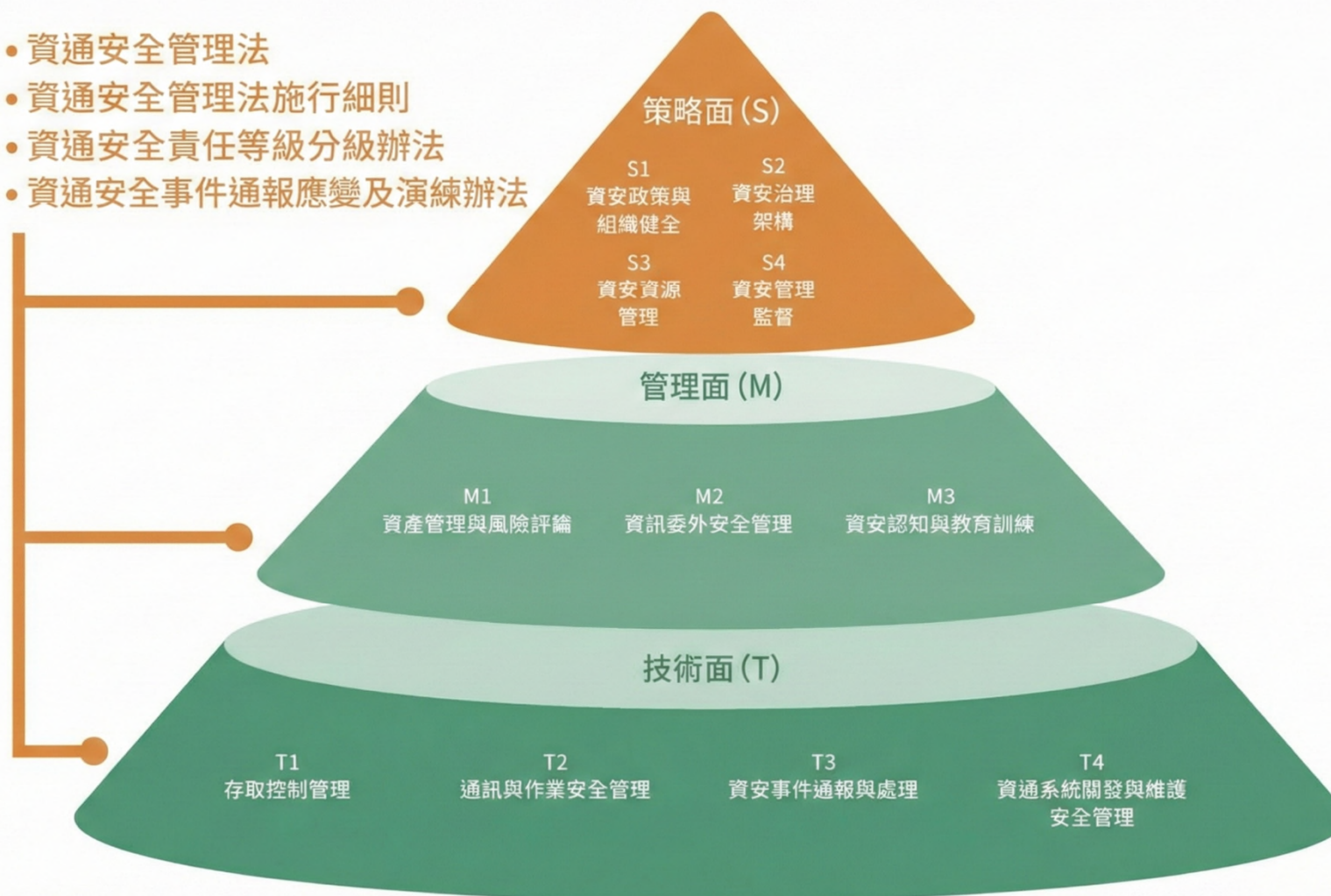




4-6 資安治理成熟度評估(3/9)

■ 資安治理架構與相關法規關聯

- 資通安全管理法
- 資通安全管理法施行細則
- 資通安全責任等級分級辦法
- 資通安全事件通報應變及演練辦法





4-6 資安治理成熟度評估(4/9)

■ 流程構面與目標

面向	流程構面	目標範圍	
策略	S1 資安政策與組織健全	- 資安政策建立 - 資安組織與管理審查	- 資安相關法規遵循
	S2 資安治理架構	- 資安新興議題評估 - 利害關係人溝通	- 重要資安資訊揭露
	S3 資安資源管理	- 資安資源規劃	- 資安專職人員配置
	S4 資安管理監督	- 內部資通安全稽核 - 資安管理制度落實	- 業務持續運作管理
管理	M1 資產管理與風險評鑑	- 資訊資產盤點 - 資安風險管理	- 資通系統分級與防護基準落實
	M2 資訊委外安全管理	- 委外廠商資安專業能力 - 委外廠商資安管理	- 委外廠商資安稽核
	M3 資安認知與教育訓練	- 資安專職人員技能 - 資安認知與教育訓練	- 資安證照與職能證書 - 資安政策與宣導要求
技術	T1 存取控制管理	- 網路安全管理 - 權限管理	- 加密管理
	T2 通訊與作業安全管理	- 惡意軟體管理 - 遠距工作管理 - 電子郵件安全 - 實體環境控制措施 - 系統備份 - 儲存媒體防護 - 行動裝置管理	- 資通安全監控 - 資通安全防護 - 政府組態基準 - 安全性檢測 - 資通安全弱點通報 - 端點偵測及應變機制
	T3 資安事件通報與處理	- 資安事件通報應變 - 日誌紀錄保存 - 資安情資評估與因應 - 政府領域資安聯防情資	- 資安事件通報應變逾時 - 網路攻防弱點比例 - 社交工程演練郵件開啟率 - 社交工程演練郵件點閱率
	T4 資通系統開發與維護安全管理	- 部署環境威脅更新修補 - 資通系統開發安全設計 - 資通系統開發安全測試	- 源碼安全管理 - 作業環境區隔



4-6 資安治理成熟度評估(5/9)

■ 能力度等級定義

- 依據ISO/IEC33020：2015定義能力度(Capability)等級，檢討與調整能力度等級，使應辦事項符合能力度等級要求

能力度等級	能力度定義	累進要求	
Level 5 最佳化流程 (Optimizing Process)	- 基於過去執行成效分析或其他 創新方式 <u>強化與優化該流程</u>	需滿足 Level 1~4	
Level 4 可預測流程 (Predictable Process)	- 該流程可透過衡量結果了解 執行成效 - 該流程 <u>已被量化管理</u>	需滿足 Level 1~3	
Level 3 標準化流程 (Established Process)	- 該流程 <u>已被標準化</u> - 該流程 <u>已被有效地部署</u>	需滿足 Level 1~2	範圍擴大或深化 應辦事項要求
Level 2 已管理流程 (Managed Process)	- 該流程執行過程 <u>已被管理</u> - 該流程 <u>產出已被管理</u>	需滿足 Level 1	符合應辦 事項 要求
Level 1 已執行流程 (Performed Process)	該流程之執行結果已達預先設定	-	
Level 0 未執行流程 (unperformed Process)	組織未建立該流程或無法達成該 流程	-	



4-6 資安治理成熟度評估(6/9)

■ 成熟度等級定義

- 依ISO/IEC 33004：2015 定義成熟度(Maturity)等級，評估組織資安治理成熟度

成熟度等級	成熟度定義	累進要求
Level 5 創新型 (Innovating)	透過識別創新應用、技術、新機會或潛在風險優化各流程構面	Level 1至Level 5之流程構面皆達能力度等級5
Level 4 可預測型 (Predictable)	依組織目標定義流程量化指標,建立穩定、可預測之流程,蒐集與分析歷史數據,持續改善	Level 1至Level 4之流程構面皆達能力度等級4
Level 3 制度化型 (Established)	有效定義與部署標準化流程,使其成為常規作業	Level 1至Level 3之流程構面皆達能力度等級3
Level 2 管理型 (Managed)	相關流程構面已進行管理,包含規劃、執行及監督之過程	Level 1至Level 2之流程構面皆達能力度等級2
Level 1 基礎型 (Basic)	相關流程構面執行結果已達成預先設定,且可支持組織之業務	Level 1之流程構面皆達能力度等級1
Level 0 未成熟型 (Immature)	係指組織尚未有效執行相關之基本流程	Level 1之任一流程構面能力度為0



4-6 資安治理成熟度評估(7/9)

■ 成熟度等級與流程構面之對應關係

成熟度等級	流程構面名稱
5	S2資安治理架構
4	S4資安管理監督
3	S3資安資源管理
	T3資安事件通報與處理
	T4資通系統開發與維護安全管理
2	M1資產管理與風險評鑑
	M2資訊委外安全管理
	T1存取控制管理
1	S1資安政策與組織健全
	M3資安認知與教育訓練
	T2通訊與作業安全管理



4-6 資安治理成熟度評估(8/9)

■ 資安治理成熟度等級計算範例

成熟度等級	流程構面名稱	檢核項目 題號範圍	流程構面 能力度等級
5	S2資安治理架構	第4~6題	1
4	S4資安管理監督	第9~11題	2
3	S3資安資源管理	第7~8題	3
	T3資安事件通報與處理	第40~47題	2
	T4資通系統開發與維護安全管理	第48~52題	4
2	M1資產管理與風險評鑑	第12~14題	4
	M2資訊委外安全管理	第15~17題	3
	T1存取控制管理	第22~24題	4
1	S1資安政策與組織健全	第1~3題	4
	M3資安認知與教育訓練	第18~21題	4
	T2通訊與作業安全管理	第25~39題	3

機關整體成熟度

Level 2

成熟度等級1至等級3
對應之流程構面(S1、
M3、T2、M1、M2、
T1、S3、T3及T4)，
其能力度等級未全數
達能力度3(含)以上，
故成熟度等級未達
Level 3。

成熟度等級1至等級2
對應之流程構面(S1、
M3、T2、M1、M2
及T1)，其能力度等級
皆達能力度2(含)以上，
故成熟度等級滿足
Level 2。

成熟度等級1對應之流
程構面(S1、M3及T2)，
其能力度等級皆達能
力度1(含)以上，故成
熟度等級滿足Level 1。



4-6 資安治理成熟度評估(9/9)

■ 資安治理評估推動方式





4-7 認知與訓練

■ 資通安全認知與訓練應辦事項

辦理項目		辦理內容	A級 機關	B級 機關	C級 機關	D級 機關	E級 機關
資通安全 教育訓練	資通安全 專職人員	每人每年至少接受12小時以上之 資通安全專業課程訓練或資通安 全職能訓練。	V			無要求	
	資通安全 專職人員 以外之資 訊人員	每人每2年至少接受3小時以上之 資通安全專業課程訓練或資通安 全職能訓練，且每年接受3小時以 上之資通安全通識教育訓練。	V			V	無要求
	一般使用 者及主管	每人每年接受3小時以上之資通安 全通識教育訓練。	V				
資通安全專業證照 及(或)職能訓練證書		公務機關：資通安全專職人員各 自持有證照及證書各一張以上， 並持續維持證照及證書之有效性。	至少 4名	至少 2名	至少 1名	無要求	
		特定非公務機關：資通安全專職 人員各自持有證照或證書各一張 以上，並持續維持證照或證書之 有效性。	V			無要求	

備註：資通安全專職人員以外之資訊人員：指其他實際從事資通安全業務或資訊業務之人員。

資通安全專業證照：指由主管機關認可之國內外發證機關(構)所核發之資通安全證照；

職能訓練證書：指參與由主管機關認可之資安訓練機構所開設的職能課程，並經評量合格取得訓練證書。



第4單元-分組討論

1. 機關於識別與判斷資通系統的「機密性、完整性、可用性、法律遵循性」受資安事件影響時，可能造成的衝擊等級（高/中/普）有哪些具體的挑戰？在資源有限的情況下，機關如何依據分級結果，優先實施附表十的控制措施？
2. 機關進行營運持續計畫時，如何有效進行營運衝擊分析 (BIA)，特別是如務實地設定核心資通系統的復原時間目標 (RTO)、復原點目標 (RPO) 及最大可容忍中斷時間 (MTPD)？有哪些評估方法或考慮因素是關鍵？
3. 機關規劃哪些演練情境(例如系統中斷、惡意攻擊、複合式災難)最具代表性或最值得演練？如何設計一場能讓各部門(不只 IT)積極參與並從中學習，確保其熟悉災害復原作業 的有效演練？
4. 機關如何確保高層主管（負責治理）與執行層人員（負責管理）之間有效溝通與協作，將治理的目標及要求轉化為管理的行動，共同提升組織整體資安水準？並分享推動成熟度從低等級向高等級邁進的關鍵步驟有哪些？